



國立臺灣大學管理學院碩士在職專班資訊管理組

碩士論文

Executive MBA Program in Information Management

College of Management

National Taiwan University

Master Thesis

企業資訊安全治理與管理框架實作探討：

金融業個案研究

A Study on Implementation of Enterprise Information

Security Governance and Management Framework：

Financial Industry Case Study

詹中傑

Jung-Jay Jan

指導教授：林永松 博士

Advisor: Yeong-Sung Lin, Ph.D.

中華民國 111 年 1 月

January 2022

國立臺灣大學碩士學位論文
口試委員會審定書



企業資訊安全治理與管理框架實作探討：金融業
個案研究

A Study on Implementation of Enterprise
Information Security Governance and Management
Framework : Financial Industry Case Study

本論文係詹中傑君（學號 P07747015）在國立臺灣大學
管理學院碩士在職專班資訊管理組完成之碩士學位論文，於
民國一一一年一月十八日承下列考試委員審查通過及口試
及格，特此證明

口試委員：

林永松

（指導教授）

孔令陽

翁崇雄

吳學良

系主任、所長

陳建銘

致謝



本論文之完成，首先衷心感謝林永松教授的指導與包容，給了筆者思考與發揮的時間與空間，讓我可以順利完成我在人生中「第二曲線」後「第三曲線」的修煉。

在 EMBA 第一學期「資訊科技與競爭策略」課程中，我體會了策略的影響力與重要性，促發我開始思考應如何選擇研究方向，也決定了「策略」與「管理」兩個已與我工作緊密結合的題目。

感謝 107A 班各位學長姐，能與各位同窗共學，真是我修來的福氣，讓我在生活與工作再次升級與進化，也感謝同組的好夥伴 Ben 哥、女神、文生、超殺女、卡爾文（排名依學號順序），每個人都這麼的優秀、認真、親切，亦是筆者修習各門課程的好夥伴。

感謝家人的支持，讓我在上課的時候，能專心致志，在參加活動時，無後顧之憂，而在寫論文的時候，能留給我一個干擾最少的地方，瞄準目標，戮力以赴。

最後，感謝當初面試我，讓我進入 EMBA 的五位老師，翁崇雄、曹承礎、莊裕澤、盧信銘、孔令傑五位教授，因為老師們，我得以進入臺大就讀，開啟一個向學術界、產業界頂尖人才學習的大門，走上資訊管理的新高處，邁向企業管理的新世界。感謝有幸遇到班導師吳學良、孔令傑兩位教授的指導，讓我在修習學業之外獲得更多在專業及人生的啟發。

詹中傑 謹識
于臺大管理學院
民國 111 年 1 月

中文摘要



金融業為國家資通安全戰略的一環，亦為資通安全管理法所定義之關鍵基礎設施之一，故在資訊安全(Information Security)工作的執行上，金融業皆需依循政府主管機關訂定之各項規範，規劃並執行相關工作，然而在面對更進一步資訊安全治理(Information Security Governance)的問題時，若仔細檢視各層級規範，在相關規範中，對於能明確協助金融業高階主管據以執行策略與管理架構之建議，則尚未看到有完整之串聯及論述。

為了協助金融業高階主管資訊安全治理的最佳實務思考，本研究採取個案研究法，結合筆者於 EMBA 課程中所學環境(Environment)、文化(Culture)、策略(Strategic)、組織(Organization)、人才(People)，簡稱 ECSOP 架構，及國際電腦稽核協會(ISACA)企業資訊安全模型(Business Model for Information Security)、美國國家標準暨技術研究院(NIST)網路安全框架(CSF)，提出資訊安全治理與管理框架實作建議，並利用以下七項步驟，期望提供金融業參考，以協助有效建立資訊安全治理機制，並進一步提高資訊安全治理成熟度：

- 一、 審視內外議題權重，擬定資安策略。
- 二、 依據組織資源特性，設計治理架構與資安權責。
- 三、 校準金檢核重點，持續完備資安規範。
- 四、 順應國際主流趨勢，培育資安人才發展。
- 五、 鞏固縱深防禦，慎選資安合作夥伴。
- 六、 建立資安韌性與金融生態聯防體系。
- 七、 形塑全面資安文化，提升資安治理成熟度。

最後本研究以某金融業實例，驗證所提出的「資訊安全治理與管理框架實作建議」對金融業的適配性與可行性，並提出可依據下列指標評量資訊安全治理成效：

- 一、 資安治理成熟度評估結果。
- 二、 內外部稽核缺失數量。
- 三、 資安人才證照比例。
- 四、 接受並通過資安培訓的人員的比例。
- 五、 社交工程演練點擊率。



- 六、 專案如期如質如預算達成率。
- 七、 關鍵風險指標達成率。
- 八、 發生作業風險事件等級之資安事件數量。
- 九、 資安事件通報查處回應成效。
- 十、 作業符合服務水準及復原時間目標等指標。

本研究期望可提供金融業高階主管參酌評估所擬訂的資訊安全治理策略是否適當，所投入的防禦資源是否適量，及所衡量的績效指標是否適切的呈現資安治理成熟度。

關鍵字：資訊安全治理、資安治理、資訊安全框架、資安框架、資訊安全績效、資安績效、資訊安全治理成熟度、資安治理成熟度

THESIS ABSTRACT

**INFORMATION MANAGEMENT
COLLEGE OF MANAGEMENT
NATIONAL TAIWAN UNIVERSITY**



NAME : Jung-Jay Jan

MONTH/YEAR : January 2022

ADVISER : Yeong-Sung Lin, Ph.D.

**TITLE : A Study on Implementation of Enterprise Information Security
Governance and Management Framework : Financial Industry Case
Study**

The financial industry is a part of the national information security strategy and it is also one of the key infrastructures defined by the Information Security Management Law. Therefore, the financial industry needs to plan and execute related work in accordance with various regulations set by the government authority. However, when facing the issue of further information security governance, we have not yet seen a complete discussion or clearly suggestion to assist the senior executives in the financial industry to implement the strategy and management structure.

To assist senior executives in the financial industry to think about the best practice of information security governance, this study adopts a case study method, combining with environment, culture, strategy, organization, and people that the author has learned in the EMBA course, and ISACA business model for information security, and the NIST Cyber Security Framework. The author provides recommendations on the implementation of security governance and management frameworks, and using the following seven steps to assist the financial industry as a reference to effectively establish an information security governance mechanism and further improve the maturity of information security governance :

1. Review the weight of internal and external issues first, and then formulate an information security strategy.
2. Design governance structure and the division of information security rights and responsibilities based on the characteristics of the organization's resources.
3. Aiming at the focus of inspection by the competent authority, continuously improve internal regulations of information security.
4. Follow the upcoming international trends to cultivate and develop information



security talents.

5. Consolidate defense in depth, and carefully select information security partners.
6. Establish information security resilience and establish a joint defense system for the financial ecosystem.
7. To shape comprehensive information security culture and enhance the maturity of information security governance.

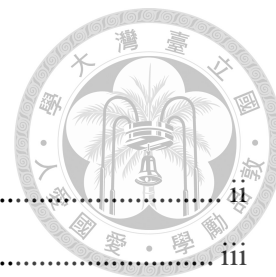
Finally, this study uses a financial industry example to verify the suitability and feasibility of the proposed "information security governance and management framework implementation recommendations" for the financial industry, and proposes that we can measure the effectiveness of information security defense based on the following indicators:

1. The results of the information security governance maturity assessment.
2. The number of examinations finding of internal or external audits.
3. Proportion of information security personnel with professional licenses.
4. The percentage of people who have received information security training and passed the exam.
5. The percentage of people defrauded in social engineering exercises.
6. The proportion of projects completed on scheduled, on quality and on budget.
7. Key risk indicator achievement rate.
8. The number of information security incidents that match the level of operational risk incidents.
9. The efficiency of reporting, investigating, and responding to information security incidents in accordance with internal regulations.
10. The proportion of system that meet the service level commitment and meet recovery time objective.

This research is expected to provide senior executives in the financial industry to consider whether the proposed information security governance strategy is appropriate, whether the amount of defense resources invested is appropriate, and whether the measured performance indicators are appropriate to show the maturity of information security governance.

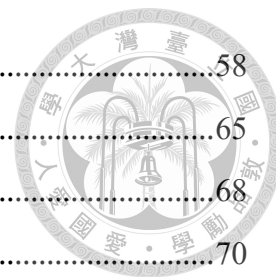
Keywords: information security governance, information security framework, information security performance, information security governance maturity.

目錄



口試委員會審定書	ii
致謝	iii
中文摘要	iv
THESIS ABSTRACT	vi
目錄	viii
圖目錄	x
表目錄	xi
第一章 緒論	1
第一節 、研究背景	1
第二節 、研究動機與目的	2
第三節 、研究範圍	3
第四節 、研究流程	4
第二章 文獻探討	5
第一節 、資訊安全治理	5
第二節 、資訊安全框架	10
第三節 、資訊安全防禦技術	16
第四節 、資訊安全績效評量	20
第三章 資訊安全治理與資訊安全框架之整合應用	34
第一節 、資安治理與資訊安全框架整合應用	36
第二節 、資安防護與資訊安全框架整合應用	37
第三節 、資安韌性與資訊安全框架整合應用	38
第四節 、資安治理與資安績效	40
第五節 、資安治理與管理框架建構步驟	43
第四章 建構符合資安治理與管理框架實作研究—金融業個案研究	46
第一節 、個案公司概况	46
第二節 、審視內外議題權重，擬定資安策略	48
第三節 、依據組織資源特性，設計治理架構與資安權責	52
第四節 、校準金檢查核重點，持續完備資安規範	56

第五節 、順應國際主流趨勢，培育資安人才發展	58
第六節 、鞏固縱深防禦、慎選資安合作夥伴	65
第七節 、建立資安韌性與聯防體系	68
第八節 、形塑全面資安文化，提升資安治理成熟度	70
第五章 結論與建議	72
第一節 、研究結論	72
第二節 、研究限制	75
第三節 、後續研究建議	76
參考文獻	77



圖目錄



圖 1-1 研究流程.....	4
圖 2-1 資訊安全治理與資訊技術治理間之關係.....	5
圖 2-2 資訊安全治理模型.....	9
圖 2-3 BMIS 概觀.....	10
圖 2-4 台灣資安市場地圖.....	16
圖 2-5 台灣資安產品及服務通過能量登錄服務機構地圖.....	18
圖 2-6 CGTF 資安治理成熟度評估模型.....	28
圖 2-7 ITGI 資安治理成熟度模型.....	29
圖 2-8 Gartner 資安治理成熟度評估模型.....	30
圖 2-9 ISO 27001 資安治理成熟度評估模型.....	31
圖 2-10 SABSA 資安治理成熟度評估模型.....	32
圖 2-11 FFIEC 資安治理成熟度評估模型.....	33
圖 3-1 資安治理構面.....	35
圖 3-2 建構國家資安聯防體系.....	38
圖 3-3 資安治理構面與關鍵資安績效指標關聯圖.....	41
圖 3-4 建構完整資訊安全治理構面七步驟.....	43
圖 4-1 A 公司與其子公司資安組織權責架構示意圖.....	47
圖 4-2 A 公司與其子公司資安組織雙線報告關係.....	52
圖 4-3 資訊單位與資安專責單位的關係第 1 種.....	53
圖 4-4 資訊單位與資安專責單位的關係第 2 種.....	53
圖 4-5 資安人才需求與職能職責對應關係.....	61
圖 4-6 A 公司資訊安全專責人員績效指標.....	71

表目錄

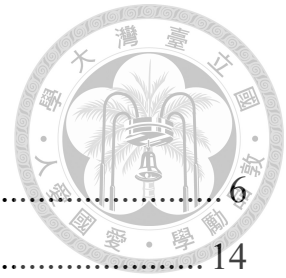


表 2-1 資訊安全治理定義彙集	6
表 2-2 NIST CSF 框架實施層級定義表	14
表 2-3 台灣資安市場地圖資安產品與服務名稱排序表	17
表 2-4 台灣資安產品及服務通過能量登錄服務機構地圖名稱排序表	19
表 2-5 NIST SP800-55 資訊安全績效量測指南績效指標範例	20
表 2-6 ISO 27004 資訊安全管理量測標準量測範例	23
表 4-1 資安專責單位應辦事項	55
表 4-2 資安專職人力職能	59
表 4-3 產業資安專業人才主要職責	59
表 4-4 金融業資安證照規範要求與證照排行相關參考資料	62
表 4-5 A 公司採用資安產品與服務與 NIST CSF 5 大功能對應關係	67



第一章 緒論

第一節、研究背景

自有資訊科技的使用以來，就有資訊安全的問題，尤其我國由於政治環境的特殊性，長期以來被作為中美兩大強權資訊安全攻防的練兵場，行政院於 2001 年通過「建立我國通資訊基礎建設安全機制計畫」後，2016 年才正式提出「資安即國安」的戰略願景，2018 年 6 月 6 日才正式公布了資通安全管理法，2018 年 9 月才提出第一份「國家資通安全戰略報告」，明訂「打造安全可信賴的數位國家」之戰略願景，並制定「打造國家資安機制，確保數位國家安全」、「建立國家資安體系，加速數位經濟發展」、「推動國防資安自主研發，提升產業成長」之戰略目標^{註1}。

金融業為國家資通安全戰略的一環，亦為資通安全管理法所定義之關鍵資訊基礎設施之一，雖金融監督管理委員會(以下簡稱金管會)在 2016 年提出的「金融科技發展策略白皮書」中已提到「資訊安全是未來管理重點」^{註2}，而其推動策略則是依資訊治理、網路安全、個資保護、災害應變、委外管理等五大範圍，然而在實務上，金融業之資訊安全權責主管，應如何校準 2018 年提出的「國家資通安全戰略」？如何因應「金融科技發展策略」？尤其是在國內金融業經歷 2016 年 7 月第一銀行自動提款機被國際駭客盜領，2017 年 5 月 12 日勒索病毒 WannaCry 攻擊，2017 年 1 月第一次證券商集體遭到 DDoS(Distributed Denial-of-Service)攻擊勒索，2017 年 10 月遠東商業國際銀行發生國際匯款系統 SWIFT 被駭客入侵盜轉 18 億元等事件之後，金管會終於在 2020 年 8 月推出「金融資安行動方案」，至此，如何更有效能的去建構適合且符合資訊安全治理的管理機制並提高成熟度，於 2020 年已成為金融業當務之急。

本研究擬探討一金融業公司，旗下包含銀行、保險、證券等多種業態子公司在 2017 年之時空背景下，是如何擬定適當資安策略，如何選擇管理框架，如何設計績效評量指標去引導旗下子公司，建構互助合作機制，發揮聯合防禦之效益，提供其建立可提升資安治理成熟度良好基礎之經驗供金融業資安權責主管參考。

註1 總統府，2018，*國家資通安全戰略報告*

註2 金融監督管理委員會，2016，*金融科技發展策略白皮書*

第二節、研究動機與目的

金融業在資訊安全工作的執行上，皆依循政府主管機關訂定之各項規範，如金融機構資訊系統安全基準、金融機構辦理電腦系統資訊安全評估辦法、運用新興科技應注意事項、證券期貨業資通安全檢查機制、保險業辦理資訊安全防護自律規範等，去規劃並執行相關工作，然而在面對資訊安全治理等更高層次的管理議題時，上述操作層級的作業規範，並無法明確協助金融業高階主管去擬定據以執行的資安治理策略與提供管理架構建議。

自 2017 年 2 月 24 日金管會第一次邀集本國銀行討論設置資訊安全專責單位後，陸續出台了對銀行、保險、證券等金融相關行業要求設置資訊安全專責單位的相關法令規範，金管會接著又於 2020 年 8 月推出「金融資安行動方案」，實施至今，在金融行業中，擔負資訊安全專責之高階主管，如資安長（Chief Information Security Officer）應需要思考以下議題：

- 一、如何與董事會成員報告資安治理成效？
- 二、如何因應快速變化的時空環境，考量資訊系統環境與資訊安全威脅，評估公司所需面對的資訊安全風險？
- 三、隨著集團的併購與擴張，如何在子公司不同業態文化下，還能營造能校準集團策略的資訊安全文化？
- 四、如何在資源有限的情況下，去擬定能平衡風險與成本的聯防策略？
- 五、資訊安全專責單位與資訊單位要如何分工合作才能有落實資訊安全工作？
- 六、在資訊安全人才短缺的情況下，如何選用育留資訊安全人才？
- 七、如何設計與部署資訊安全防護機制，有效防禦資訊安全威脅？
- 八、如何評量資訊安全防禦成效，評估資訊安全治理成熟度？

為了在學術上補強上層資訊安全治理與下層資訊安全管理架構設計關聯性之研究，在實務上提供金融業資安長在資訊安全治理時，有一個適用於金融業的資訊安全治理策略與資訊安全管理框架的實務建議，本研究目的如下：

- 一、探討資訊安全治理與資訊安全框架等相關文獻及其如何整合應用。
- 二、嘗試提出適合資訊安全權責主管使用與董事會溝通的資訊安全治理架構（如圖 3-1 資安治理構面所示）。
- 三、以某金融業個案分析驗證本研究的可行性與有效性。

第三節、研究範圍

本研究探討金融業資訊安全治理與資訊安全管理框架之關係，以及評量資訊安全治理成效及持續提升資訊安全治理成熟度的關鍵要素，並嘗試提出一個能結合上述兩者之資訊安全治理架構及實作建議，並以某金融業公司個案進行理論與實務的驗證，確保本研究所提出的建議具備參考價值。

第四節、研究流程

在研究背景環境下，筆者產生研究動機與目的，在思考並選擇研究範圍後，先進行相關理論與文獻探討，接著進行理論文獻與研究案例資料蒐集，整理出研究主題與框架之關係，並進行個案分析研究，最後歸納研究結論並提出建議，如圖 1-1。

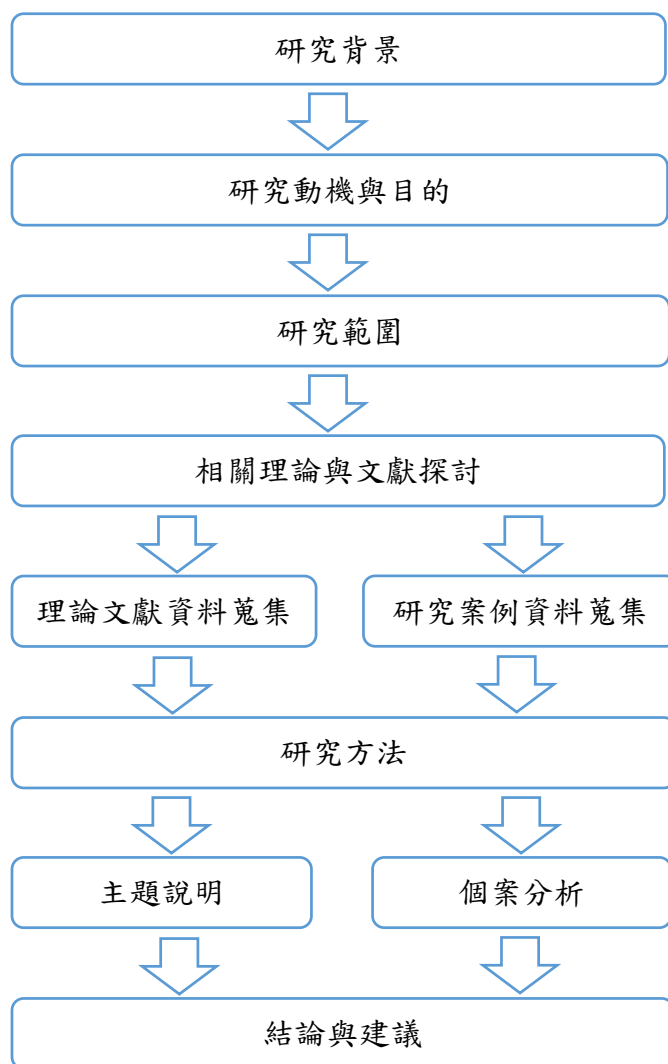


圖 1-1 研究流程

第二章 文獻探討



第一節、資訊安全治理

金管會於 2013 年發布「強化公司治理藍圖」，透過推動「公司治理評鑑」讓企業重視並持續提升公司治理水平，2016 年「金融科技發展策略白皮書」中提到金融機構需具備內部控制與稽核、風險管理及公司治理三把健全經營之鑰，2019 年新增「公司是否建置資訊安全風險管理架構，訂定資訊安全政策及具體管理方案，並揭露於公司網站或年報？」之評鑑指標，2020 年「金融資安行動方案」更明確訂定「強化資安監理」、「深化資安治理」、「精實金融韌性」、「發揮資安聯防」等四大策勵方向，至此金融業資訊安全高階主管如何協助董事會進行資訊安全治理已成為刻不容緩之議題。依據資訊安全治理國家標準 CNS 27014 規範，組織治理（即公司治理）監督及影響資訊安全治理，而資訊安全治理範圍則包含「資訊安全治理」本身，以及「資訊技術治理」部分，如圖 2-1。以下將探討資訊安全治理的定義與國際標準。

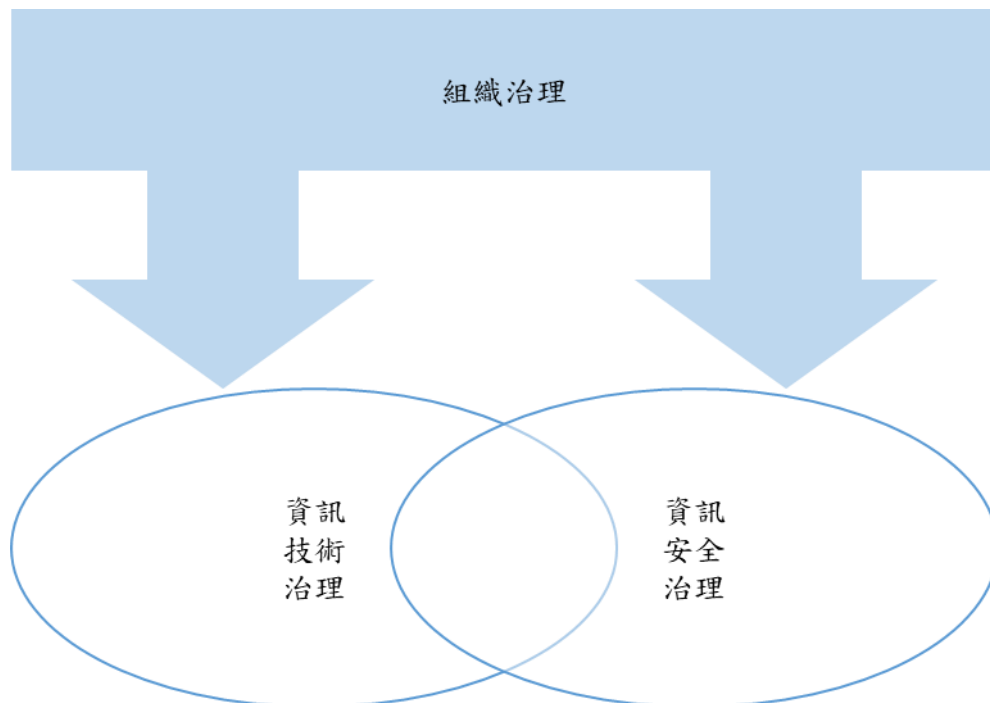


圖 2-1 資訊安全治理與資訊技術治理間之關係

資料來源：CNS 27014，2013



一、資訊安全治理定義

本研究蒐集各方資訊安全治理的定義如表 2-1：

表 2-1 資訊安全治理定義彙集

定義來源	年份	定義說明
CNS 27014	2013	資訊安全治理是指導及控制組織資訊安全活動的系統。
蕭瑞祥	2013	資安治理是為建立與維護提供資訊安全策略與組織目標一致，並符合相關法律規章的架構。
樊國楨與黃健誠	2009	資訊安全治理能定義為建立與維護框架、支援管理之結構及程序，以及提供下列保證的過程：在努力管理風險下，使資訊安全策略與業務目標一致、支援業務目標，藉由嚴守政策與內部控制以符合相關法規，以及提供職責之指派。
S.H. Von Solms and R.Von Solms	2009	資訊安全治理是將管理承諾和領導力、組織結構、用戶認知和承諾、政策、程序、流程、技術和合規性執行等機制，以上所有要素集合以確保及維護公司電子資產（數據，信息，軟件，硬件，人員等）的機密性，完整性和可用性。
National Institute of Standards and Technology (NIST)	2006	資訊安全治理可以定義為一個透過建立和維護框架並支持管理結構和流程以管理風險的過程，通過遵守政策和內部控制及適用的法律法規，並提供責任分配，以確保資訊安全戰略與業務目標保持一致並支持業務目標。
王東紅、孫強、陳偉	2004	信息安全治理是指最高管理層(董事會)用來監督管理層在信息安全戰略上的過程、結構及與業務的關係，以確保信息安全戰略與組織的業務目標的一致。
Posthumus, Shaun, and Rossouw von Solms	2004	資訊安全治理是描述執行階層如何處理資通安全相關議題的過程，且與組織的資訊治理架構、組織策略相結合，監督組織資通安全計畫的執行，提供策略性的指揮及適當的風險管理，以確保達成組織目標，並為董事會與高階主管的責任。
Moulton and Coles	2003	資訊安全治理是控制環境的建立與維護，以管理關於資訊機密性、完整性、可用性的風險，以及此資訊的流程與系統。
Williams, Paul	2001	資訊安全治理乃是「一種董事會及執行者的責任，屬於公司治理的部份，它包含了領導、組織結構與程序並執行資訊技術政策，以確保組織的資訊技術維持並延伸組織的政策與目標，以達到企業競爭優勢之組織能力」。

資料來源：本研究整理

二、資訊安全治理標準

國際標準組織(International Organization for Standardization，其創始人將其簡稱 ISO) 是一個獨立的非政府國際組織，召集專家製定與市場有關的國際標準，是制定全世界工商業國際標準的機構，企業亦大量使用或參考其所制定之各類國際標準，以利與股東、顧客溝通，並藉由通過國際標準認證以證實其商業信譽，我國國家標準(National Standards of the Republic of China，簡稱 CNS)亦常參考 ISO 標準，故透過 ISO 27014：2013 可進一步了解國際標準對資訊安全治理的要求，中文翻譯將參考 CNS 27014 與國家教育研究院雙語詞彙、學術名詞暨辭書資訊網(以下簡稱國家教育研究院)，

(一) 資訊安全治理重要名詞定義

(1) 執行管理階層(Executive Management)

由治理單位委派責任的個人或一群人，為達成組織之目的而實作策略及政策。

(2) 治理單位(Governing Body)

負責組織之績效及符合性的個人或一群人。

(3) 資訊安全治理(Governance of Information Security)

指導及控制組織資訊安全活動之系統。

(4) 利害關係人(Stakeholder)

可影響、受影響或感知到本身會被組織活動所影響之任何個人或組織。

(二) 資訊安全治理之目標

(1) 策略校準(Strategy Alignment)

資訊安全目標及策略應校準其業務目標及策略。

(2) 價值貢獻(Value Delivery)

貢獻價值給治理單位及利害關係人。

(3) 可歸責性(Accountability)

確保資訊風險被適當的因應。



(三) 資訊安全治理原則

(1) 建立全組織之資訊安全

應該確保其安全範圍的完整性，應完整涵蓋組織所有活動。

(2) 採用基於風險之作法

應依據組織之風險胃納定義可接受風險等級，然後採取適當的風險管控措施，所考量風險可能包括競爭優勢、法律責任、營運中斷、商譽受損、財務損失、客戶信賴等。

(3) 設定投資決策方向

應依據營運目標，建立資訊安全投資策略，以促成營運與資訊安全要求之平衡，並滿足利害關係人之需求。

(4) 確保符合內部及外部需求

應確保資安政策與相關規範，符合法令法規要求、營運服務水平、契約等外部或內部要求，並可藉由獨立公正的第三方進行驗證。

(5) 培養安全良好之環境

應充分溝通協調利害關係人，以求在需求、目標、角色、責任與資源等議題達到共識或一致性的方向，溝通協調機制可透過會議、教育訓練、宣導等方式進行。

(四) 資訊安全治理流程

治理單位透過評估(evaluate)、指導(direct)、監視.monitor)及溝通(communicate)等流程，以治理資訊安全，另透過保證(assure)提供關於資訊安全治理所達到等級的獨立及客觀意見，其關係如圖 2-2。

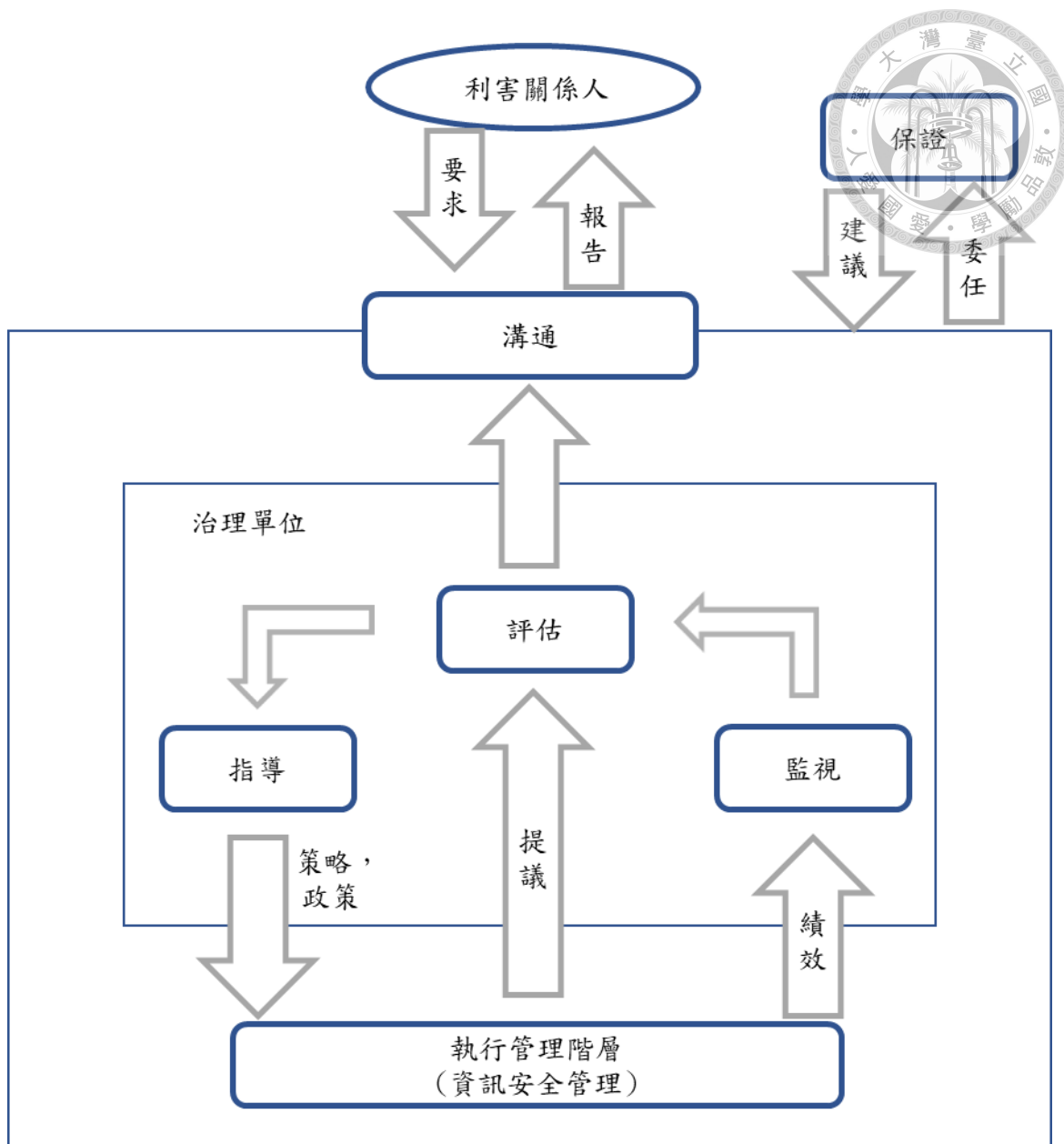


圖 2-2 資訊安全治理模型
資料來源：CNS 27014，2013

第二節、資訊安全框架

框架(framework)一詞，教育部重編國語辭典解釋為「事物的格式與架構」，劍橋字典(Cambridge Dictionary)解釋為「a system of rules, ideas, or beliefs that is used to plan or decide something」，政府多會參考國際資訊安全標準或框架、或法令法規趨勢去擬訂資訊安全相關法令規範，故資訊安全框架提供一種通用的語言，除可以協助金融業資安主管以系統化的邏輯去思考資安策略，亦有利於與內部、外部利害關係人溝通企業資安作為之必要性與有效性，以下就我國金融業較常使用之資訊安全框架簡介說明：

一、Business Model for Information Security (BMIS)

國際電腦稽核協會(Information Systems Audit and Control Association, 簡稱ISACA)是一個為資訊管理、控制、安全和稽核專業設定規範的全球性組織，ISACA於2010年提出企業資訊安全模型(Business Model for Information Security, 簡稱BMIS)如圖2-3，提供一種系統性思考的方案，期望能兼容於當時已存在的各類與資訊安全相關之框架(如COBIT、ISO 27000、Risk IT、NIST SP 800-53等)，透過更清楚地描述影響資訊安全的可能因素及其交互關係，讓資安管理人員更能從不同角度思考自身環境與業務特性，識別出可能導致問題的所有因素，在符合企業目標的原則下管理資訊安全。

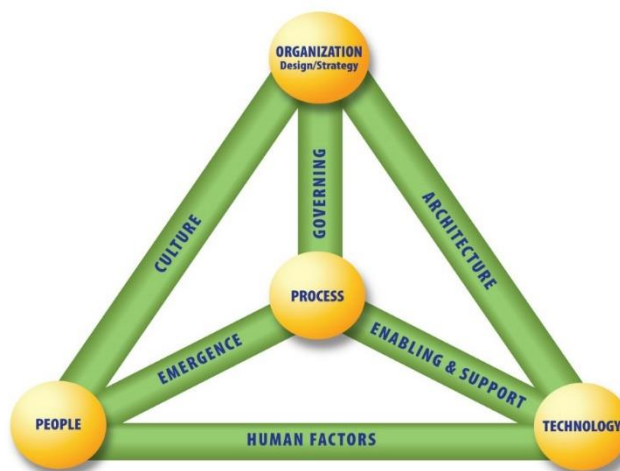


圖 2-3 BMIS 概觀

資料來源：ISACA BMIS，2010



以下就 BMIS 中的模型中的主要元素與其動態互連關係進行說明：

(一) 主要元素 (Elements)

BMIS 是一個三維空間的模型，由四個主要元素(Elements)組成，分別是組織(Organisation)、人員(People)、技術(Technology)、流程(Process)，分述如下：

(1) 組織 (Organisation)

BMIS 將組織定義為人員交互作用的網路關係，此關係會受企業規模、企業策略、組織結構(正式或非正式，階層式或矩陣式)、企業地理分布(如全球型企業還是區域型企業)、企業文化、業務型態(如金融業、傳統產業、製造業、高科技業)等內涵影響；組織因素將決定資訊安全的策略與目標，以及期望資訊安全應帶給企業的價值。

(2) 人員 (People)

BMIS 認為人員代表企業組織中的人力資源，如正職員工、約聘員工、外包商、供應商、協力廠商等，以及其他可以影響企業資訊安全的相關利害關係人，如股東、客戶、政府、媒體、投資者等，每個人都有自己的想法、價值觀、偏好與對資訊安全的需求或期望，人是最核心也是最難控制的要素。

(3) 技術 (Technology)

BMIS 將技術定義為「知識的實際應用，特別是在特定領域中的應用」和「知識的實際應用所賦予的能力」；技術可涵蓋水電空調等基礎設施、硬體、軟體，可以是具體的工具，也可以是企業技術的水平的一種展現。BMIS 強調技術的導入應該是一個不斷去思考是否技術能符合業務需求的循環，如果技術解決方案有任何疑慮，就必須回到原點去釐清業務需求是什麼。

(4) 流程 (Process)

BMIS 引述 ISACA 制定的「Risk IT 框架」對流程的定義，「Risk IT 框架」將流程定義為「執行某項任務的可信賴且可重複的活動及控制措施的組合」；組織中會有負責執行該流程的權責單位或人員，會有輸入來源、處理步驟、然後輸出結果，流程是實現業務目標的手段，必須要有衡量流程績效的指標，如果流程定義良好，可管理、可衡量、可持續改善優化，則表示流程已成熟。



(二) 動態互連關係 (Dynamic Interconnections, 簡稱 DIs)

(1) 文化 (Culture)

文化連結組織與人員，BMIS 認為「強調文化這個動態互連關係是區分 BMIS 與其他安全模型之關鍵」，BMIS 定義「文化是一種行為、信念、假設、態度和做事方式」，文化會影響組織行為、團體行為與個人行為；企業內部因素，如管理、薪酬、獎懲、晉升等人事制度，企業外部因素如宗教，種族、社會經濟背景、地理位置和個人經歷，都與文化的形成有關。

(2) 治理 (Governing)

治理連結組織與流程，BMIS 認為「治理是董事會和執行管理層執行的一系列職責和實踐，旨在提供戰略方向，確保實現目標，確定風險得到適當管理並驗證企業資源得到合理使用」。治理會影響組織架構以及人員、技術、流程等其他要素如何協作以達成組織的使命和戰略。組織透過治理讓管理流程能符合董事會設定的目標與方向。

(3) 架構 (Architecture)

架構連結組織與科技，BMIS 引用 ISO / IEC 42010:2007 對架構之定義為「系統在其環境中之基礎概念或性質，以其元件、關係及其設計與演進原則體現之」；架構應依據企業目標來設計，可以是概念性的、邏輯性的、實體的架構，在 BMIS 中，組織可透過架構去驅動技術要達到的目標，技術則可透過架構反饋訊息給組織。

(4) 湧現性 (Emergence)

湧現性連結人員與流程(參考國家教育研究院的翻譯，在此將 Emergence 翻譯為「湧現性」)，在人員與流程之間，隨著新的業務、新的行為、新的流程、新的安全機制的產生，加上人員會對規範有認知與解釋差異，或是規範可能不完整或不清楚，以上都會不斷產生許多混亂的情況與問題，企業應學習從混亂中找出有秩序的做事方式去解決問題，並持續改善相關流程。

(5) 賦能與支持 (Enabling and Support)

「賦能與支持」連結技術與流程(參考國家教育研究院的翻譯，在此將 Enabling 翻譯為「賦能」)，企業必須依據需求選擇、評估所需的技術，並設計適當的運作流程去搭配技術，讓技術與流程互相支持、彼此賦能，才能發揮使用該技術或流程去滿足需求，並達到期望的效率與效果。

(6) 人因因素 (Human Factors)

人因因素連結人員與技術(參考國家教育研究院的翻譯，在此將 Human Factors 翻譯為「人因因素」)，企業應了解人員能力、人體工學與人類技能的限制，並將其理解應用於技術與流程的開發、設計、導入上。



二、NIST Cyber Security Framework (NIST CSF)

美國國家標準技術研究院(National Institute of Standards and Technology，簡稱 NIST)，成立於 1901 年，其使命為藉由進步的量測科學、標準和技術以強化經濟安全性、改善生活品質，並促進美國的創新能力與產業競爭力。NIST 於 2013 年召集了一群產業、學界、政府等公私領域專家共同協作，參考了當時的資安標準、指南和企業實務做法，於 2014 年提出網路安全框架(Cybersecurity Framework，簡稱 CSF)，期望透過此框架，協助組織以風險為基礎，評估自身資安防護現況，與期待達成的資安防護水準之差異，找出改善路徑，並使用具成本效益的方法，管理和降低網路安全風險，並可促進內外部利害關係人之溝通效益，目前已發展至 2018 年 1.1 版。

NIST CSF 由框架核心(Framework Core)、框架實施層級(Framework Implementation Tiers)、框架輪廓(Framework Profiles)三個部分組成，以下就此三部分進行說明：

(一) 框架核心(Framework Core)

框架核心提供一系列網路安全活動，可協助達到可實現的特定目標成果、及通用的參考性文獻，共有 5 大功能(Function)、23 個類別(Category)、108 個子類別(Subcategory)；框架核心提供從一個網路安全生命週期，涵蓋事前、事中、事後的完整觀點，讓組織去思考應該具備的規範或機制，以下說明框架核心的 5 個功能：

(1) 識別(Identify)

幫助組織了解並進而管理系統、人員、資產、資料和能力等網路安全相關風險。識別功能中包含資產管理、商業環境、治理、風險評估、風險管理策略、供應鏈風險管理等 6 個類別(Category)。

(2) 防護(Protect)

發展並實施適當的防護機制措施，確保關鍵基礎服務的提供。防護功能中包含身分管理，身分驗證和訪問控制、意識和培訓、資料安全性、資訊保護流程和程序、維護、保護技術等 6 個類別。



(3) 偵測(Detect)

發展並實施適當機制措施，以識別網路安全事件的發生。偵測功能中包含異常和事件、安全持續監控、檢測流程等 3 個類別。

(4) 回應(Respond)

發展並實施適當機制措施，以採取適當行動回應網路安全事件。回應功能中包含回應計畫、溝通、分析、緩解、改進等 5 個類別。

(5) 復原(Recover)

發展並實施適當機制措施，以維持業務持續，並恢復被網路安全事件影響的功能或服務。復原功能中包含復原計畫、改進、溝通等 3 個類別。

(二) 框架實施層級(Framework Implementation Tiers)

框架實施層級描述組織內實施風險管理時，所展現符合「框架定義的特徵」的程度，從第 1 級、第 2 級、第 3 級到第 4 級，表示越來越嚴格且複雜的程度，組織應該考量其所面對的威脅環境、法令法規要求、業務目標、供應鏈安全要求、組織自身限制等因素，並在成本效益分析證明可有效降低風險時，去選擇適合自己的期望達到的框架實施層級，說明整理如表 2-2。

表 2-2 NIST CSF 框架實施層級定義表

構面 層級	風險管理流程	整合的風險管理計畫	外部參與
層級 1： 部分 (Partial)	- 風險管理沒有正式的流程，比較像是臨時且被動的處理風險。 - 網路安全活動的優先順序與組織目標、威脅環境、業務需求無直接關聯。	- 組織層面對網路安全風險的認知較缺乏。 - 組織獲得網路安全資訊的管道沒有規律，且無法有效率的共享資訊。	- 組織不了解自身在生態系統環境中的角色。 - 組織不與生態系中利害關係人合作或共享資訊，也未意識到其供應鏈風險。
層級 2： 了解風險 (Risk Informed)	- 風險管理措施已獲得核准，但還未成為組織的政策。 - 網路安全活動的優先順序受到組織目標、威脅環境、業務需求的直接影響。	- 組織層面已經認知到網路安全風險，但尚未確認管理網路安全風險的方法。 - 組織內部以非正式的方式共享網路安全資訊。	- 組織通過了解其供應鏈上游或下游，而了解組織在生態系統中的角色，但並非對上下游都了解。 - 組織從其他實體接收資訊，但並未共享資訊。

構面 層級	風險管理流程	整合的風險管理計畫	外部參與
		組織會對資訊資產進行網路風險評估，但並未重複執行。	組織能認知到其提供和使用的產品與服務相關的供應鏈安全風險，但並未正式採取行動。
層級 3： 可重複 (Repeatable)	- 風險管理措施已獲得核准，並且以組織的政策形式呈現。 - 網路安全活動的優先順序受到組織目標、威脅環境、業務需求的直接影響，並且根據環境變化不斷調整。	- 已有組織層面的方法可管理網路安全風險，並按計畫實施與審查。 - 有統一的方式，去應變風險的變化。 - 組織可持續準確的監控網路安全風險。 - 人員具備相關的知識與技能。	- 組織了解其所在生態系統環境中，自身應扮演的角色 - 組織定期與其他實體分享訊息。 - 組織認知到供應鏈風險，並且採取適當的行動。
層級 4： 已適應 (Adaptive)	- 可透過數據對實務作業進行持續改善。 - 組織可及時因應不斷變化的技術發展與威脅，並進行有效的回應。	- 風險管理已成為組織文化 - 有明確的規範去管理網路安全風險及處理網路安全事件。 - 組織可以快速有效地處理並傳達風險的變化。 - 組織預算已考量預期的風險環境與風險承受能力。	- 組織了解其所在生態系統環境中，自身與其供應鏈之資安議題，並且為其做出貢獻。 - 組織內部、外部皆可進行資訊分享，並使用及時的資訊來理解風險。 - 組織使用正式和非正式機制與供應鏈溝通，維持與供應鏈穩固的關係。

資料來源：NIST CSF，2018、本研究整理

(三) 框架輪廓(Framework Profiles)

框架輪廓是組織在考量業務需求、風險承受能力、資源投入限制後，對前述功能、類別、子類別進行選擇後得出的結果，通過將現況(目前輪廓)與期望達成的目標(目標輪廓)比較，可以識別差異，並據以擬定行動計畫。

第三節、資訊安全防禦技術

孔子曾說：「工欲善其事，必先利其器」，隨著資訊科技的進步，企業透過選擇適合自己的資訊科技，可以創造競爭優勢，也可以讓客戶享受更便利、更優質的服務，同樣的，資訊安全的技術也必須配合新科技的使用持續進步，企業對於資訊技術的採用，除考量自身需求與效益，亦須考量取得成本、維護成本等因素，故欲探討資安技術，筆者擬從 iThome 製作的「台灣資安市場地圖」、與中華民國資訊軟體協會製作的「台灣資安產品及服務通過能量登錄服務機構地圖」來檢視我國企業可能使用到的資訊安全技術或服務，至於技術之內涵，將不在本文中探討。

一、台灣資安市場地圖

iThome 電腦周刊是一家於 1997 年成立，長期報導企業資訊應用，IT 管理，資訊產品與技術發展等主題，為台灣資訊類雜誌中發行量最大的 IT 雜誌。iThome 於 2018 年開始將資安產品與解決方案進行分類，首次發布了「台灣資安市場地圖」如圖 2-4，期望透過此圖讓企業用戶能簡單快速掌握各類資安產品的全貌，進而選擇適合自己的產品，截至 2021 年 2 月 24 日，該圖已更新至 BETA23 版，涵蓋 33 種資安產品與服務。

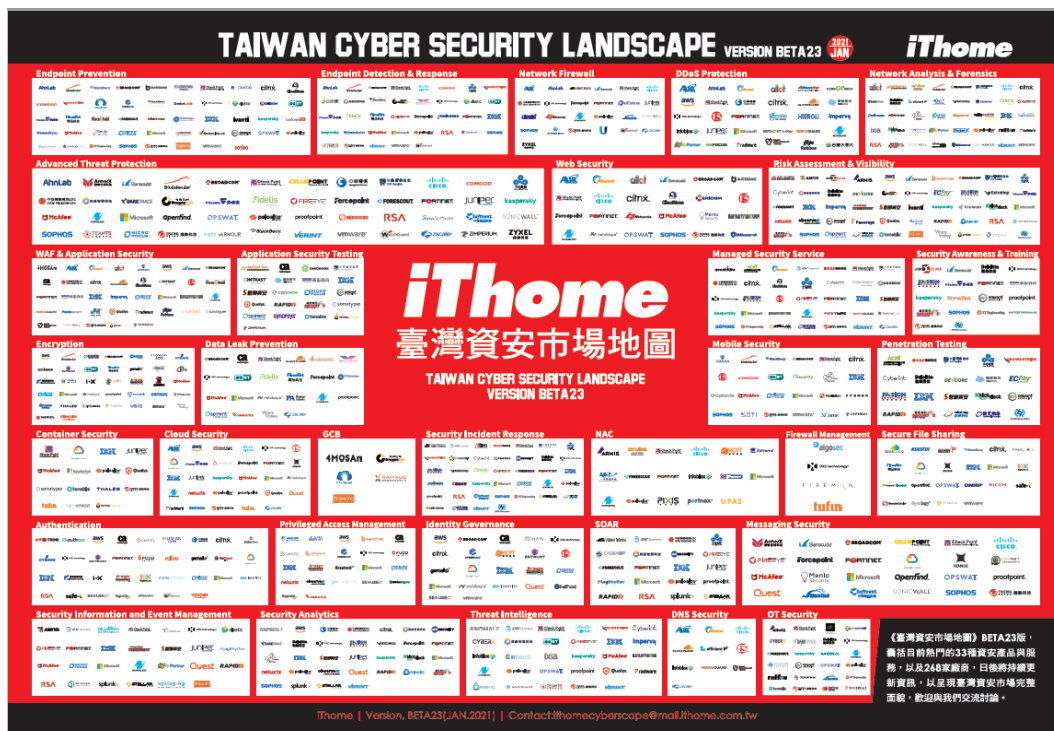


圖 2-4 台灣資安市場地圖
資料來源：iThome，2021

筆者將圖 2-4 中分類依英文字母排序整理如表 2-3，以利本研究第三章進行探討及後續應用。



表 2-3 台灣資安市場地圖資安產品與服務名稱排序表

項次	台灣資安市場地圖資安產品與服務名稱排序
1	Advance Threat Protection
2	Application Security Testing
3	Authentication
4	Cloud Security
5	Container Security
6	Data Leak Prevention
7	DDoS Protection
8	DNS Security
9	Encryption
10	Endpoint Detection & Response
11	Endpoint Prevention
12	Firewall Management
13	GCB
14	Identity Governance
15	Managed Security Services
16	Messaging Security
17	Mobile Security
18	NAC
19	Network Analysis & Forensics
20	Network Firewall
21	OT Security
22	Penetration Testing
23	Privileged Access Management
24	Risk Assessment & Visibility
25	Secure File Sharing
26	Security Analytics
27	Security Awareness & Training
28	Security Incident Response
29	Security Information and Event Management
30	SOAR
31	Threat Intelligence
32	WAF & Application Security
33	Web Security

資料來源：iThome、本研究整理

國立臺灣大學
分類與登錄機制

產業環境，而中華

通過能量登錄服務

er20201130 版，涵

應用系統防護產品

、主機安全防護產品、帳號掛損與檢測產品、網頁內
分與存取控制產品、憑證註冊管理系統產品、公鑰金
安全防護產品、沙箱檢測產品、白名單防護技術產品

聯數位 中華建網 四零四 光動科技 全家軟體
聯數位 協志聯合 尚承科技 優基科技 達而思
聯數位 華新科技 飛捷電腦 精品科技 順華資訊
聯數位 趨勢科技 威寶全球 網龍

資料安全防護產品

電子郵件防護產品、內容過濾產品、檔案硬碟加
密產品、資料備份與還原產品、資料加解密產品、
產品、安全事件分析產品、資安事件回應產品

聯數位 全家軟體 安華聯網 宏華豐 尚承科技
聯數位 眾至資訊 綠盾科技 華能科技 華碩資訊
聯數位 順華資訊 華越科技 達安智慧 華碩資訊

資安管理產品

件管理平台、資安風險分析產品、
式攻擊防護引擎(APT engine)

聯數位 安華聯網 宏華豐 飛迅科技 達華智能

數位鑑識產品

、數位鑑識資料收集產品、密碼破解工具產品、
具產品、數位鑑識產品、行動裝置鑑識產品

精品科技 聯數位

行動與雲端防護產品

、行動裝置後門分析與防護產品、雲端防護產品

聯數位 趨勢科技

物聯網防護產品

、物聯網產品、內嵌式系統防護產品

科智企業 達而思 博度科技 趨勢科技

電信通訊安全防護產品

電信通訊安全防護軟體體

轉控制系統安全防護產品

產品、遠端控制系統病毒與惡意程式防護產品

資信偵查產品

資安偵查分享與分析產品

安華資訊 宏安國際 綠盾科技 關貿網路

區塊鏈安全產品

區塊鏈安全產品

關連結

 中華民國資訊軟體協會
Information Software Industry Association of R.O.C

資料來源：經濟部工業局，2020

筆者將圖 2-5 中分類依中文字母筆畫排序整理如表 2-4，以利本研究第三章進行探討。



表 2-4 台灣資安產品及服務通過能量登錄服務機構地圖名稱排序表

項次	資訊安全服務	項次	資訊安全產品
1	行動與雲端安全防護服務	1	行動與雲端防護產品
2	物聯網安全防護服務	2	物聯網防護產品
3	提供資訊安全教育訓練	3	區塊鏈安全產品
4	資料安全防護服務	4	資安情資產品
5	資訊安全防護能力分析與評估	5	資安管理產品
6	資訊安全或個人資料管理系統驗證	6	資料安全防護產品
7	資訊安全或個人資料管理架構規劃與建置	7	運轉控制系統安全防護產品
8	資訊安全營運管理服務	8	電信通訊安全防護產品
9	資訊系統安全防護服務	9	網路傳輸防護產品
10	運轉控制系統安全與防護服務	10	數位鑑識產品
11	電信通訊安全與防護服務	11	應用系統防護產品
12	網路傳輸安全防護服務		
13	數位鑑識採證與分析服務		

資料來源：經濟部工業局、本研究整理



第四節、資訊安全績效評量

在第一節資訊安全治理模型中，提到「資訊安全執行管理階層」須呈報績效給「治理單位」，而「治理單位」則透過監視(Monitor)績效，進行資訊安全治理，在第二節 BMIS 資訊安全框架中，也提到必須要有衡量流程績效的指標，因為實施績效管理，可以讓企業對自己所處現狀進行反思與展望，並保證始終在做正確的事情，而不是只把事情做正確(MBA 智庫百科)，且管理者可藉由評估資訊安全管理系統控制措施實施有效性定量數據的資訊安全度量，獲得組織實施資訊安全政策、過程及執行程序之客觀證據，以判定資訊安全管理系統之控制措施，是否達成所規劃預定達成之控制目標程度與有效性(樊國禎、林樹國、黃健誠等人，2005)。因此，若要確認企業資安治理及其管理框架是否有效，應妥善選擇績效評量的方法及指標。以下就我國企業較常參考使用之資訊安全績效評量方法及指標進行說明。

一、資訊安全績效量測指南

美國國家標準技術研究所(National Institute of Standards and Technology, NIST)發布之資訊安全績效量測指南(Performance Measure Guide for Information Security，簡稱 NIST SP800-55)，目前為 2008 年版，該指南於附錄 A 共提供了 19 個量測指標可供企業參考使用，整理如表 2-5，以利本研究第三章進行探討。

表 2-5 NIST SP800-55 資訊安全績效量測指南績效指標範例

編號	指標	量測意義	量測說明	公式示例
1	資安預算	提供必要的資源以適當的保護組織資訊與資訊系統	用於資訊安全的機構資訊系統預算的百分比	$(\text{資訊安全預算}/\text{機構總資訊科技預算}) \times 100$
2	弱點管理	確保所有弱點被識別並減輕其風險	高風險弱點被發現後，在組織定義的時間內緩解的百分比	$(\text{在目標期間內(高風險漏洞被緩解數量}/\text{高風險漏洞被發現總數量)}) \times 100$
3	存取控制	限制對可識別、已知、可信和授權的個人或機器的資訊、系統和組件訪問。	用於獲得未經授權的訪問的遠程訪問點的百分比。	$(\text{未經授權的訪問的遠距訪問點}/\text{所有遠距訪問點}) \times 100$

編號	指標	量測意義	量測說明	公式示例
4	認知與訓練	確保組織中的人員備適當的訓練以執行所賦予的資安職掌	接受過安全培訓的資訊系統安全人員的百分比	$(\text{過去一年完成安全培訓的資訊系統安全人員} / \text{資訊系統安全人員總人數}) * 100$
5	審計與問責	產出、保護、保留資訊系統稽核軌跡以利監控分析調查及呈報非法、未授權、不當活動	檢視及分析稽核軌跡以找出不當活動的平均頻率	報告期內的平均頻率
6	認證、認可和安全評估	確保所有資訊系統均已依要求獲得認證和認可	在實施之前已完成認證和認可的新系統的百分比	$(\text{實施之前已完成認證和認可的新系統} / \text{新系統總數}) * 100$
7	組態管理	組織在整個系統開發生命週期中應建立及維護資訊系統的組態與資產	在最新的自動化基線組態中確定的已批准和實施的組態更改的百分比	$(\text{最新的自動化基線組態中確定的已批准和實施的組態更改數量} / \text{所有經由自動化掃描出的組態變更數量}) * 100$
8	應變計劃	建立、維護、有效執行緊急應變、備份、災難復原以確保關鍵資訊資源持續運作	每年資訊系統有執行應變計劃演練的百分比	$(\text{每年資訊系統有執行應變計劃演練的數量} / \text{資訊系統總數量}) * 100$
9	識別和驗證	所有系統使用者都依據資安政策進行識別與驗證	可以存取共享帳戶的用戶百分比	$(\text{存取共享帳戶的用戶數量} / \text{用戶總數量}) * 100$
10	事件回應	追蹤、記錄並向適當的權責單位或主管機關報告事件	追蹤、記錄並向適當的權責單位或主管機關報告事件	$(\text{根據事件等級或類別及時通報的數量} / \text{事件總數量}) * 100$
11	維護	定期與及時維護組織資訊系統並提供有效的控管(含維護使用的工具、機制、人員)	系統組件根據正式維護計畫的維修比例	$(\text{根據正式維護計畫維護的系統組件數量} / \text{總系統組件數量}) * 100$
12	媒體保護	資訊系統媒體在報廢或再利用前進行處置、清理、淨化	含機敏資料媒體在報廢或再利用前進行處置、清理、淨化	$(\text{含機敏資料媒體在報廢或再利用前進行處置、清理、淨化和銷毀並通過檢})$

編號	指標	量測意義	量測說明	公式示例
		和銷毀	化和銷毀的比例	$\frac{\text{測的數量}}{\text{檢測媒體總數量}} * 100$
13	實體和環境	整合的實體與資訊安全保護機制以確保組織資訊資源被適當保護	發生未授權進入放置資訊系統設備場所之實體安全資安事件比例	$(\text{發生未授權進入放置資訊系統設備場所之實體安全資安事件/實體安全資安事件總數量}) * 100$
14	規劃	制定文件化且定期更新之資安計畫以規範人員資安行為	人員皆了解並簽署資安規範協議後才能存取資訊系統	$(\text{簽署人數/系統存取總人數}) * 100$
15	人員安全	確保組織內具有權責之人員值得信賴，並符合這些職位的既定安全標準	在授權存取組織資訊與資訊系統前通過人員篩選的比例	$(\text{在授權存取組織資訊與資訊系統前通過人員篩選的人數/所有存取人數}) * 100$
16	風險評估	定期評估組織維運、資產、人員風險	弱點修補的比例	$\frac{\text{根據弱點修補行動計劃(弱點修補的數量/總弱點數量)}}{1} * 100$
17	系統和服務獲取	確保第三方提供商採用足夠的安全措施來保護從組織外包的信息、應用程序和服務	包含安全要求或規格的系統與服務採購合約比例	$(\text{包含安全要求或規格的系統與服務採購合約數量/總系統與服務採購合約數量}) * 100$
18	系統和通訊保護	配置充足的資源以適當的保護資訊基礎建設	使用經 FIPS 140-2 驗證的加密模組執行所有加密操作的移動計算機和設備的百分比，這些模組在核准的操作模式下運行	$(\text{使用經 FIPS 140-2 驗證的加密模組執行所有加密操作的移動計算機和設備的數量/總移動計算機和設備的數量}) * 100$
19	系統和信息完整性	提供對抗惡意程式的保護機制，監控資訊系統、發出安全警示並採取適當應變作為	作業系統弱點有修補或採取緩解措施的百分比	$(\text{已實施補丁、確定為不適用或已授予豁免的分佈式警報和建議中解決的漏洞數量/通過警報和建議以及通過漏洞掃描確定的適用漏洞總數}) * 100$

資料來源：NIST SP800-55，2008、本研究整理

二、ISO 27004 資訊安全管理量測標準

國際標準組織(International Organization for Standardization, ISO)於 2009 年發布之 ISO 27004 資訊安全管理量測標準，目前已發展至 2016 年版，此標準於附錄 B 共提供了 36 個量測指標可供企業參考使用，整理如表 2-6，以利本研究第三章進行探討。

表 2-6 ISO 27004 資訊安全管理量測標準量測範例

編號	指標	量測意義	量測說明	公式示例
B2	資源分配	提供必要的資源以適當的保護組織資訊與資訊系統	年度預算內分配給信息安全（內部人員、合同人員、硬件、軟件、服務）的資源明細	$(\text{資訊安全預算}/\text{機構總資訊科技預算}) \times 100$
B3	政策審查	評估是否按計劃審查資訊安全政策或是否發生重大變化	政策審查的百分比	$(\text{前一年審查信息安全政策數}/\text{已實施信息安全政策數}) \times 100$
B4	管理承諾	評估管理審查活動中管理承諾和資訊安全審查活動	1.已完成的管理審查會議 2.管理審查會議的平均參與率	1.(已完成的管理評審會議/計畫安排的管理評審會議) 2.計算管理評審會議參與率的平均值和標準差
B5	風險暴露	評估組織資訊安全風險的暴露程度	1.超出可接受風險值的中高風險 2.及時審查高、中風險	1.應定義可接受風險值，並在超出可接受風險值時提醒權責單位 2.未更新狀態的風險數量
B6	查核程序	查核程序的完整性	執行的查核總數與計劃的查核總數相比	$(\text{執行的查核總數}/\text{計劃的查核總數}) \times 100$
B7	改善行動	根據計劃驗證改善行動的狀態及其管理	如期、如值、如預算的行動計劃佔所有行動計劃的百分比	$(\text{如期、如值、如預算的行動計劃}/\text{所有行動計劃}) \times 100$
B8	安全事故支出費用	因產生資訊安全事故需支出的費用	抽樣期間發生的所有資安事故支出的費用總和	抽樣期間發生的所有資安事故支出的費用總和
B9	從資安事故中學習	確認資安事故是否促成安全現況的持續改善	促成資訊安全改善行動的資安事故數量	促進改善行動的安全事件總數/安全事件總數

編號	指標	量測意義	量測說明	公式示例
B10	執行矯正措施	評估矯正措施實施的績效	1.未實施的矯正措施的比率 2.無故未實施的矯正措施的比率 3.狀態趨勢	1.(迄今未實施的矯正措施/迄今為止計劃的矯正措施) 2.(無故未實施的矯正措施/矯正措施/迄今為止計劃採取的行動) 3.將狀態與以前的狀態進行比較
B11	ISMS 訓練與認知	量測有多少員工接受了 ISMS 相關意識培訓，並建立對組織資安政策的控制合規性	參加 ISMS 認知培訓的員工百分比	1.(接受 ISMS 培訓的員工人數/必須接受 ISMS 培訓的員工人數) * 100 2.(去年更新 ISMS 培訓的員工人數/範圍內的員工人數) * 100
B12	資安訓練	評估對年度資安培訓要求的遵守情況	接受年度資安培訓的人員百分比	(每年接受資安培訓的員工人數/需要接受年度資安培訓的員工人數) * 100
B13	資安認知合規	評估相關人員對組織安全認知政策的遵守情況	1.迄今為止的進展 2.迄今為止的簽署進展	1.(已簽署人員數量/計劃簽署人員數量) 2.將狀態與以前的狀態進行比較
B14	ISMS 認知宣導的有效性	量測員工是否理解 ISMS 認知宣導的內容	在 ISMS 認知宣導後通過測試的員工百分比	通過測試的人的百分比
B15	社交工程準備	評估員工是否準備好在社交工程攻擊的情況下做出適當的反應	對測試做出正確反應的員工百分比，如沒有在給定的釣魚郵件測試中點擊超連結	1.點擊超連結的員工人數/參與測試的員工人數 2.通報收到危險電子郵件的員工人數 3.遵循所點擊超連結的指令回應的員工人數
B16	密碼品質-手動	評估使用者用於存取組織 IT 系統的密碼的品質	1.符合組織密碼品質政策的密碼總數 2.符合組織密碼品質政策的密碼比例 3.關於密碼品質政策的合規狀態趨勢	1.符合組織密碼品質政策的密碼比例 2.關於密碼品質政策的合規狀態趨勢 3.(符合組織密碼品質政策的密碼總數/註冊密碼的數量) 4.將比例與之前的比例進行比較

編號	指標	量測意義	量測說明	公式示例
B17	密碼品質-自動化	評估使用者用於存取組織 IT 系統的密碼的品質	1.密碼總數 2.無法破解的密碼總數	1.(4 小時內無法破解的密碼數量/密碼總數) 2.將比例與之前的比例進行比較
B18	審查使用者存取權限	量測在關鍵系統上執行了多少系統的使用者存取權限審查	定期審查使用者存取權限的關鍵系統的百分比	(執行定期存取權限審查的關鍵信息系統數量/關鍵信息系統總數) * 100
B19	實體進入控制系統評估	顯示實體進入存取的系統的存在、範圍和品質	實體進入控制系統的強度	範圍從 0-5 0 沒有存取控制系統 1 有一個存取控制系統，其中 PIN 碼（一個因素系統）用於進入控制 2 有門禁卡系統，使用通行卡（單因素系統）進行門禁 3 有門禁卡系統，使用通行卡和 PIN 碼進行門禁 4 上一個 + 日誌功能已啟動 5 上一個 + PIN 碼被生物識別認證（指紋、語音識別、視網膜掃描等）取代
B20	實體進入控制有效性	1.確保人員、設施和產品的全面安全和問責環境 2.整合實體和資訊安全保護機制，確保組織的資訊資源得到適當的保護	未經授權進入包含資訊系統設施的數量	(目前允許未經授權進入包含資訊系統的設施的實體資訊安全事件數量/以前允許未經授權進入包含資訊系統的設施的實體資訊安全事件數量)
B21	定期維護管理	評估與計劃相關的維護活動的及時性	每個完成的維護事件的維護延遲	對於每個已完成的事件，從「計劃維護日期」減「實際維護日期」
B22	變更管理	評估變更管理最佳實踐和強化政策是否得到尊重	遵守變更管理最佳實踐和強化政策的新安裝系統的百分比	(有遵守變更管理最佳實踐的新安裝的應用系統的數量/新安裝的應用系統數量)
B23	防止惡意程式碼	評估系統抵禦惡意程式攻擊的有效性	未有效阻擋惡意程式攻擊之趨勢	(惡意程式引起的事件數/由惡意軟件引起的檢測和阻止的攻擊數)

編號	指標	量測意義	量測說明	公式示例
B24	防止惡意軟體	評估「防止反惡意軟件解決方案」的有效性	沒有更新「防止反惡意軟件解決方案」導致受惡意軟件影響的系統數量	(沒有更新「防止反惡意軟件解決方案」導致受惡意軟件影響的系統數量/安裝惡意軟體系統主機總數量)
B25	整體可用性	與定義的最長停機時間相比，每個服務的 IT 服務可用性	對於每項 IT 服務，將端到端可用性與最大可用性進行比較	(總可用性/最大可用性)，應排除允許停機時間
B26	防火牆規則	評估當前的防火牆效能	邊界防火牆上未使用的防火牆規則	採樣週期內使用 0 次的邊界防火牆規則計數
B27	日誌審查	評估關鍵系統日誌檔案的定期審查的合規性狀態	依規定時間需要審查的日誌檔案經審查百分比	(依規定時間審查的日誌檔案數量/日誌檔案總數)*100
B28	設備配置	驗證設備是否根據政策維持安全配置	根據政策配置的設備百分比(按類型)	(正確配置的設備數量/設備總數)*100
B29	滲透測試和漏洞評估	評估處理機敏資料的資訊系統是否容易受到惡意攻擊	自近期重大漏洞發布後，已執行滲透測試或漏洞評估的重要資訊系統的百分比	(組織定義之重要資訊系統於近期重大漏洞發布後進行滲透測試或漏洞評估系統數量/組織定義之重要資訊系統數量)*100
B30	漏洞狀況	評估組織資訊系統的漏洞級別	未修補的漏洞的權重	未修補的漏洞的嚴重性，例如 CVSS 等級*受影響系統的數量
B31	第三方協議中的安全性-A	評估第三方協議中涉及資訊安全的程度	第三方協議中涉及的相關安全要求的平均百分比	對於每個協議， ((要求的數量 - 解決的要求數量)/協議數量的總和)*100
B32	第三方協議中的安全性-B	評估第三方協議中涉及個資安全的程度	第三方協議中涉及的相關安全要求的平均百分比	對於每個協議， ((要求的數量 - 解決的要求數量)/協議數量的總和)*100
B33	資訊安全事件管理有效性	評估資訊安全事件管理的有效性	未在目標時間範圍內解決的事件	1.為每個資安事件定義其類別和應解決的目標時間 2.為超出目標時間範圍的資安事件訂定可接受目標值

編號	指標	量測意義	量測說明	公式示例
				3.比較解決時間超過目標時間範圍的事件數量，並將其計數與可接受目標值進行比較
B34	資安事件趨勢	資安事件趨勢 資安事件分類趨勢	1.在規定的時間範圍內（如一個月）的資安事件的數量 2.在規定的時間範圍內特定類別的資安事件的數量	將最近兩個時間範圍的平均量測值與最近 6 個時間範圍的平均量測值進行比較
B35	資安事件報告	量測安全事件是否得到報告和正式處理	向電腦資安事故應變小組 (CSIRT) 報告的與組織規模相關的安全事件總和	(已向 CSIRT 報告並正式處理的安全事件總數/組織定義的安全角色數量)
B36	ISMS 審核流程	評估資訊安全獨立審核的完成程度	完成獨立審核的進度比例	(第三方進行的審核數量/計劃的第三方審核總數)
B37	漏洞覆蓋	評估組織系統漏洞的及時可視性	已完成漏洞評估或滲透測試的系統的比例	上一年度漏洞評估或滲透測試的系統對像數/總系統數

資料來源：ISO 27004，2016、本研究整理



三、資訊安全治理成熟度評估

資訊安全治理成熟度評估模型，評估構面或有差異，但仍可歸納為策略、組織、人員、技術、流程等五大議題。其成熟度評級亦多分為五等分，故各模型間可互相轉換成熟度之對應關係，簡介如下。

(一) CGTF 資訊安全治理成熟度評估

Corporate Governance Task Force(簡稱 CGTF)於 2004 年提出資訊安全治理成熟度評估工具，係採用 Carnegie Mellon University 提出的 IDEAL 模型，透過起始(Initiating)、診斷(Diagnosing)、建立(Establishing)、行動(Action)、學習(Learning)等五階段來改善企業資訊安全流程，其模型如圖 2-6。

CGTF 資安治理成熟度評估模型					業務對IT 依賴程度	評估領域 得分範圍	得分範圍 顯示意義
評估 領域	業務對IT 依賴程度	風險 管理	人員	流程	很高 64~80	0 - 139	不好
評估 因子	公司特徵	企業資訊 安全風險 評估	企業資訊 安全職能 /組織	安全技 術策略		140 - 179	需要改進
				企業資訊 安全政策		180 - 220	好
				安全計 劃管理	高 48~63	0 - 119	不好
	行業特徵					120 - 164	需要改進
						165 - 220	好
					中 32~47	0 - 99	不好
						100 - 149	需要改進
						150 - 220	好
					低 16~31	0 - 84	不好
						85 - 134	需要改進
						135 - 220	好
					很低 0~15	0 - 69	不好
						70 - 119	需要改進
						120 - 220	好

圖 2-6 CGTF 資安治理成熟度評估模型

資料來源：CGTF、本研究整理

(二) ITGI 資安治理成熟度評估

美國資訊技術治理協會(IT Governance Institute，簡稱 ITGI)於 2006 年提出資訊安全治理成熟度評估模式，則將成熟度分為不存在(Non-existent)、起始(Initial)、可重複(Repeatable)、已定義(Defined)、可管理(Managed)、最佳化(Optimized)等六層(洪智能，2012)，如圖 2-7。

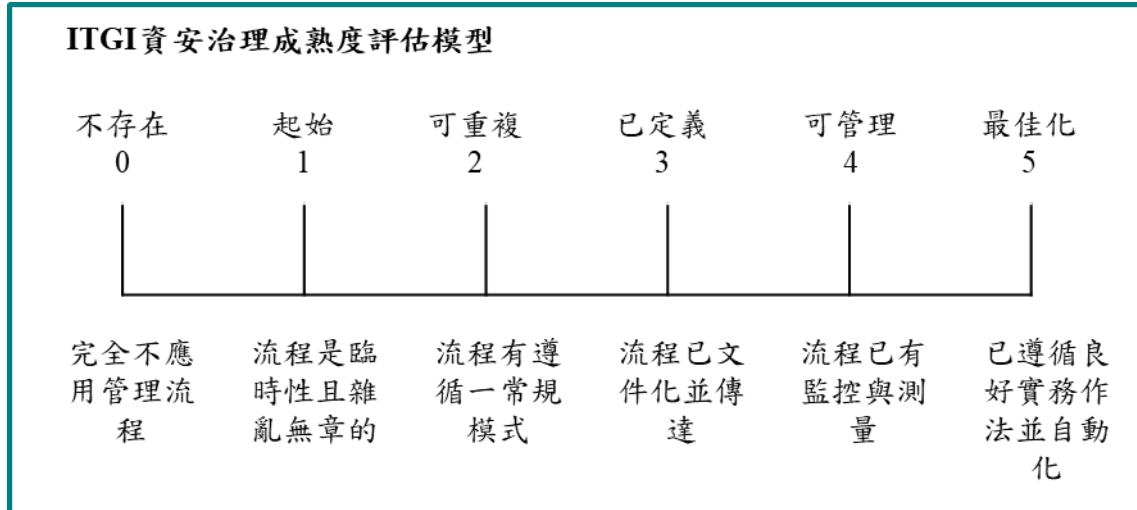


圖 2-7 ITGI 資安治理成熟度模型
資料來源：ITGI，2006、本研究整理



(三) Gartner 資安治理成熟度評估

國際知名 Gartner 顧問諮詢公司設計之資安治理成熟度評估模型，其英文名稱為 The Gartner Security Process Maturity Model，提供企業了解其資安成熟度，並進行自我改善，其模型如圖 2-8。

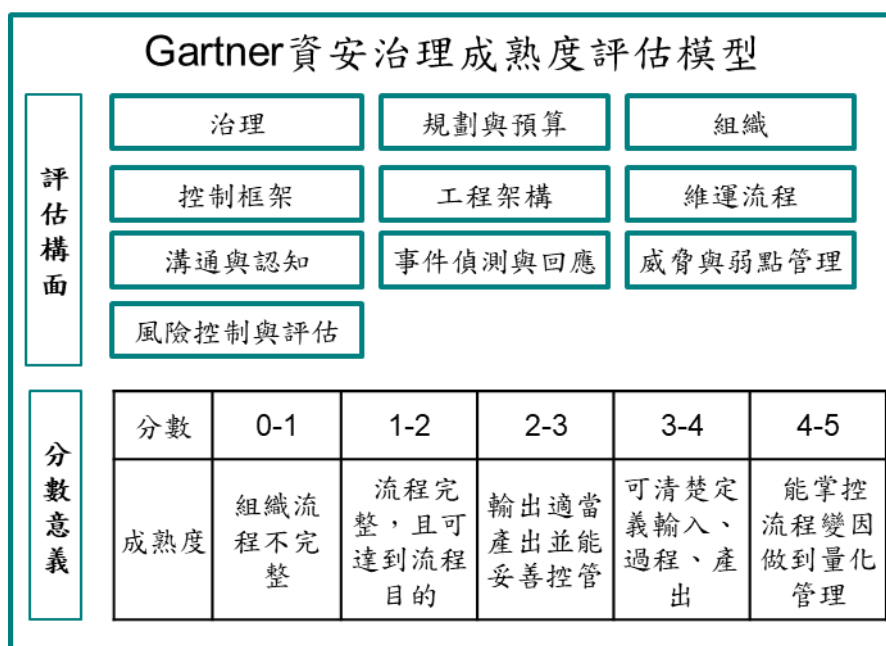


圖 2-8 Gartner 資安治理成熟度評估模型

資料來源：Gartner、本研究整理



(四) ISO 27001 資安治理成熟度評估

ISO 27001 自身提供之資安治理成熟度評估模型，提供使用 ISO27001 標準驗證之企業了解其資安成熟度，並進行自我改善，其模型如圖 2-9。

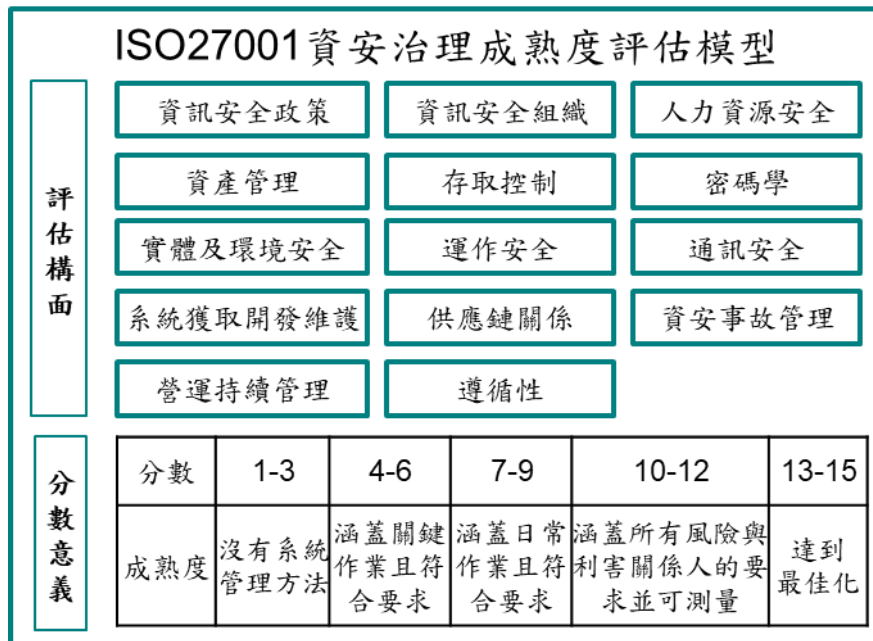


圖 2-9 ISO 27001 資安治理成熟度評估模型

資料來源：ISO 27001、本研究整理

(五) SABSA 資安治理成熟度評估

Sherwood Applied Business Security Architecture 簡稱 SABSA，是一種經過驗證的方法論，用於在企業與解決方案層級上，發展業務驅動、兼顧風險、聚焦機會的安全架構，以支持業務目標。部分國內金融業會使用 SABSA 資安治理成熟度評估模型進行成熟度評估，其模型如圖 2-10。

SABSA資安治理成熟度評估模型

評估構面		資產	動機	流程	人員	位置	時間
	語境層	業務	商業風險模型	業務流程模型	商業組織和關係	商業地理學	業務時間相依性
	概念層	業務屬性配置文件	控制目標	安全策略和架構分層	安全實體模型和信任框架	安全領域模型	安全相關生命週期
	邏輯層	商業信息模型	安全政策	安全服務	實體架構和權限配置	安全領域定義和關聯	安全處理週期
	實體層	業務數據模型	安全規則、做法和程序	安全機制	用戶、應用程序和用戶界面	平台和網絡基礎設施	控制結構執行
	組件層	數據結構	安全標準	安全產品和工具	身份、功能、存取權限	流程、節點、地址和協議	安全步驟計時和排序
	操作層	操作持續性	操作風險管理	安全服務管理和支持	應用系統和用戶管理和支持	網站和平台的安全	安全操作排程
分數意義	分數	1	2	3	4	5	
	成熟度	有證據顯示組織認知到資安議題，但尚未建立標準化流程	已有符合企業目標之架構與流程	有符合模型的完整的架構與流程	做法符合業界良好實務，並與模型架構流程整合	測量所有相關因子，並持續改善達到最佳化	

圖 2-10 SABSA 資安治理成熟度評估模型

資料來源：SABSA、本研究整理

(六) 金管會資安治理成熟度評估

金管會參考美國聯邦金融機構檢查委員會(Federal Financial Institutions Examination Council, 簡稱 FFIEC)資安評估工具(Cybersecurity Assessment Tool, 簡稱 CAT), 調適訂定適用我國金融機構之評估方法, 並鼓勵金融機構依其自有特性自行評估, 持續強化資安管理(金融資安行動方案, 2020), 為適合金融業之評估方法, 如圖 2-11。

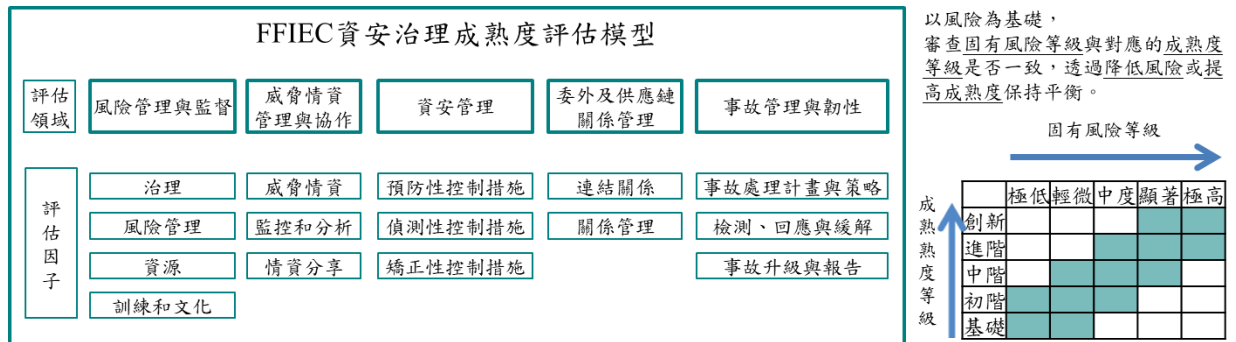


圖 2-11 FFIEC 資安治理成熟度評估模型

資料來源：FFIEC、本研究整理

第三章 資訊安全治理與資訊安全框架之整合應用

如第二章所探討，資訊安全治理是公司治理的一部分，範圍則包含「資訊安全治理」本身，以及「資訊技術治理」部分，本研究經探討資訊安全治理及國際標準、資訊安全框架、資訊安全防禦技術、資訊安全績效評量等文獻資料後，依據 CNS 27014，資訊安全治理是由管理階層的承諾和領導能力、組織結構、使用者的認知和遵循、政策、程序、流程、技術和遵守執行機制等組成，經結合筆者於 EMBA 課程中所學環境(Environment)、文化(Culture)、策略(Stratgy)、組織(Organization)、人才(People)，簡稱 ECSOP 架構，與 ISACA 提出之 BMIS 模型，與美國國家標準暨技術研究院(NIST)網路安全框架(CSF)，如圖 3-1(其中數字①至⑩為本研究整理之對應關係)，考量 2020 年「金融資安行動方案」明確訂定「強化資安監理」、「深化資安治理」、「精實金融韌性」、「發揮資安聯防」四大構面，為有利於與董事會成員溝通，本研究提出金融業可將資訊安全治理分為資安治理、資安防護、資安韌性三個主要構面，共含治理架構、制度規範、資安素養、管理機制、風險識別、防護技術、情蒐分析能力、偵測應變能力、資安聯防機制、營運持續能力等十個子構面，有利於與資訊安全框架整合應用，建構完整的資訊安全治理架構並持續提升其資訊安全治理成熟度，並可有效與內外部利害關係人溝通。

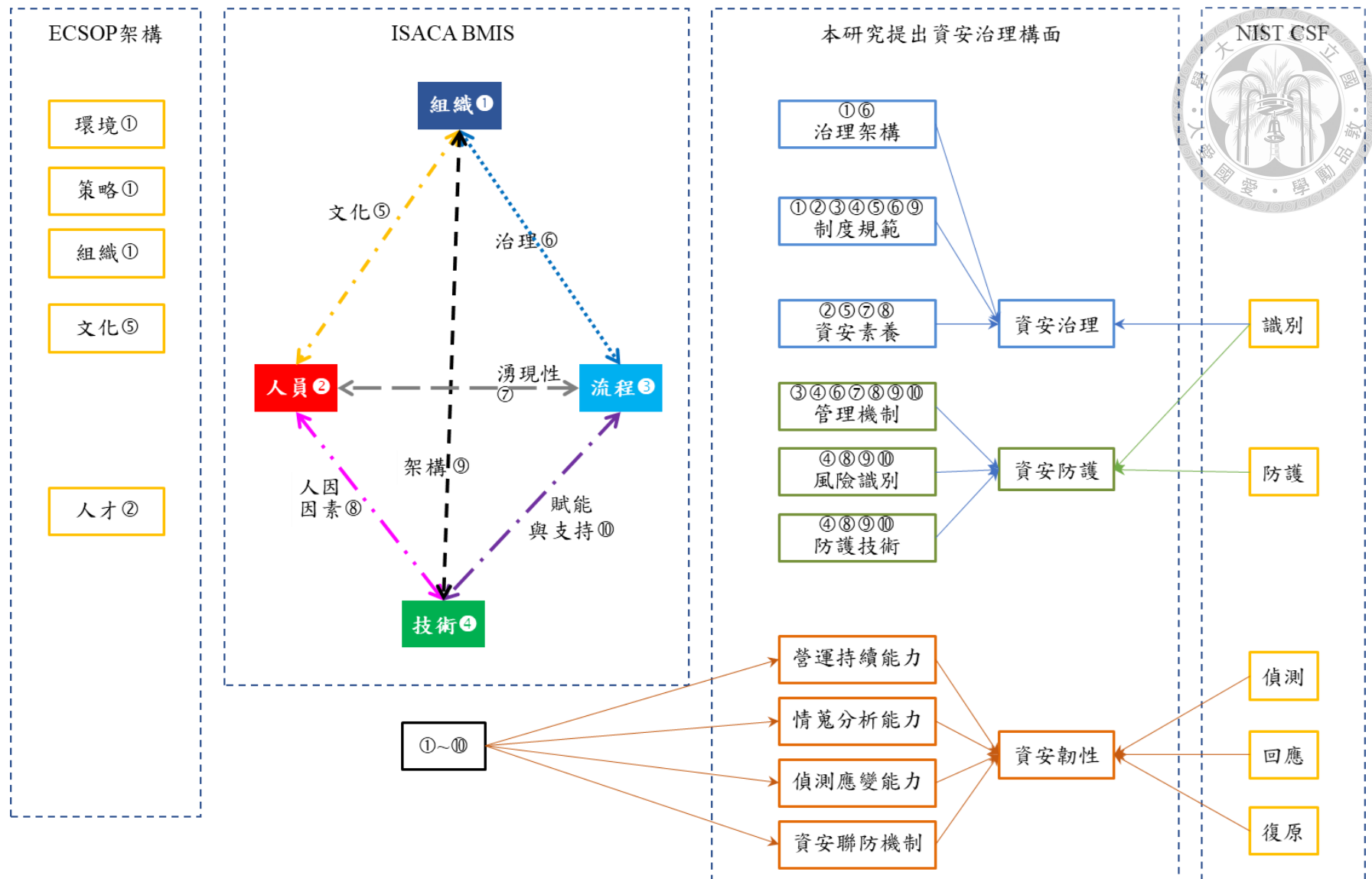


圖 3-1 資安治理構面
資料來源：本研究整理

第一節、資安治理與資訊安全框架整合應用

為了能以易於理解的方式與董事會成員溝通，本研究提出將複雜的資安治理中與董事會成員最密切相關的議題，放在資安治理主要構面，本研究認為資安治理主要構面應包含治理架構、制度規範、資安素養等三個子構面，如圖 3-1。

資訊安全治理是指最高管理層(董事會)用來監督管理層在資訊安全戰略上的過程、結構及與業務的關係，以確保資訊安全戰略與組織的業務目標的一致(王東紅、孫強、陳偉，2004)，故應設計符合企業策略需求之資訊安全治理架構，以利董事會指導、評估、監督資安管理階層(CNS 27014，2013)，上述為治理架構子構面，可對應 BMIS 模型之組織元素並透過治理(DIs)與流程元素結合。

資訊安全治理是為建立與維護提供資訊安全策略與組織目標一致，並符合相關法律規章的架構(蕭瑞祥，2013)，資訊安全治理應使資訊安全之目標及策略對齊營運目標及策略，並要求遵循法律、法規及契約，故企業應制定符合法令法規及組織策略及目標之制度規範，以確保符合內部及外部需求(CNS 27014，2013)，上述為制度規範子構面，透過制度規範才能有效將 BMIS 模型之組織元素與人員、流程、技術元素連結起來。

資訊安全治理中，人的行為是最難控制，也是最薄弱的一個環節(Johnson，2006)，但人在資訊安全上所扮演的角色非常重要，必須對資訊安全負起職責(Relyea，2008)，而文化會影響組織行為、團體行為與個人行為(BMIS，2010)，且具有資訊安全文化的組織文化，亦為高成熟度資訊安全框架應有之特徵(NIST CSF，2018)，故上述為資安素養子構面，可對應 BMIS 模型之人員元素，透過資安素養可影響人員與組織、流程、技術三元素之互動關係。

第二節、資安防護與資訊安全框架整合應用

資安防護主要構面應包含風險識別、防護技術、管理機制等三個子構面。

資訊安全治理宜經風險管理作法予以評鑑、分析及實作，並由內部控制系統支援(CNS 27014, 2013)；資訊安全治理原則係採用基於風險之作法，應依據組織之風險胃納定義可接受風險等級，然後採取適當的風險管控措施(CNS 27014, 2013)；組織層面應有方法管理網路安全風險，並按計畫實施與審查(NIST CSF, 2018)；治理是董事會和執行管理層執行的一系列職責和實踐，旨在提供戰略方向，確保實現目標，確定風險得到適當管理並驗證企業資源得到合理使用(BMIS, 2010)；故上述為風險識別子構面，風險識別與處理需及時且採用適當之資安技術方能具備成本效益，故可對應 BMIS 模型之技術元素並透過其動態互連關係(DIs)去影響組織、人員、與流程元素。

資訊安全治理範圍包含「資訊安全治理」本身，以及「資訊技術治理」部分，NIST 於 2004 年曾出版資安產品選擇指引(Guide to Selecting Information Technology Security Products)，將資安產品分為識別與認證、存取控制、入侵偵測、防火牆、公鑰基礎設施、惡意代碼防護、漏洞掃描、鑑識、媒體資料銷毀等九種類別，因其版本後來未見更新，故其分類已很難適用於現行時空背景，為有利企業思考資訊安全技術之合理範圍，建議可參照第二章之第三節「台灣資安市場地圖資安產品與服務名稱排序表」，且經分析第二章之第三節「台灣資安產品及服務通過能量登錄服務機構地圖」，可知大多資訊安全產品或資訊安全服務於分類時，其分類多標示有防護之名，且 NIST CSF 框架中，多數企業皆多優先導入防護技術，故將防護技術定為子構面，較有利於董事會成員溝通，防護技術子構面可對應 BMIS 模型之技術元素並透過其動態互連關係(DIs)去影響組織、人員、與流程元素。

「Risk IT 框架」將流程定義為「執行某項任務的可信賴且可重複的活動及控制措施的組合」，如果流程定義良好，可管理、可衡量、可持續改善優化，則表示流程已成熟，故可知成熟的流程會趨向系統化與自動化之運作，而不僅依靠人工作業，方能有利於衡量並持續優化，故本研究將上述與技術結合良好之流程稱為管理機制子構面，表示對應 BMIS 模型之技術元素並透過賦能與支持(DIs)與流程元素結合之狀態。

第三節、資安韌性與資訊安全框架整合應用

資安韌性主要構面應包含營運持續能力、情蒐分析能力、偵測應變能力、資安聯防機制等四個子構面

組織韌性是組織吸收和適應不斷變化的環境以實現其目標並生存和繁榮的能力，韌性較高的組織可以預測並應對內部和外部環境突然或逐漸變化而產生的威脅和機遇並有效管理風險(ISO 22316, 2017)，資安韌性亦被視為組織韌性的一部分；營運持續管理(Business Continuity Management System)國際標準 ISO 22301 提供了建立組織韌性的一個框架，使組織具有有效因應變化以保護其利益、聲譽、品牌和價值創造活動的能力(ISO 22301, 2019)，上述為營運持續能力子構面。

依據國家資通安全發展方案(民國 106 年至 109 年)，政府因應資安威脅加劇，將擴大建立國家資安聯防機制，建立 8 大關鍵基礎設施之資訊分享及分析中心 (Information Sharing and Analysis Center, ISAC)、電腦緊急事故處理小組(Computer Emergency Response Team, CERT)、及資訊安全監控中心 (Security Operation Center, SOC)，如圖 3-2。

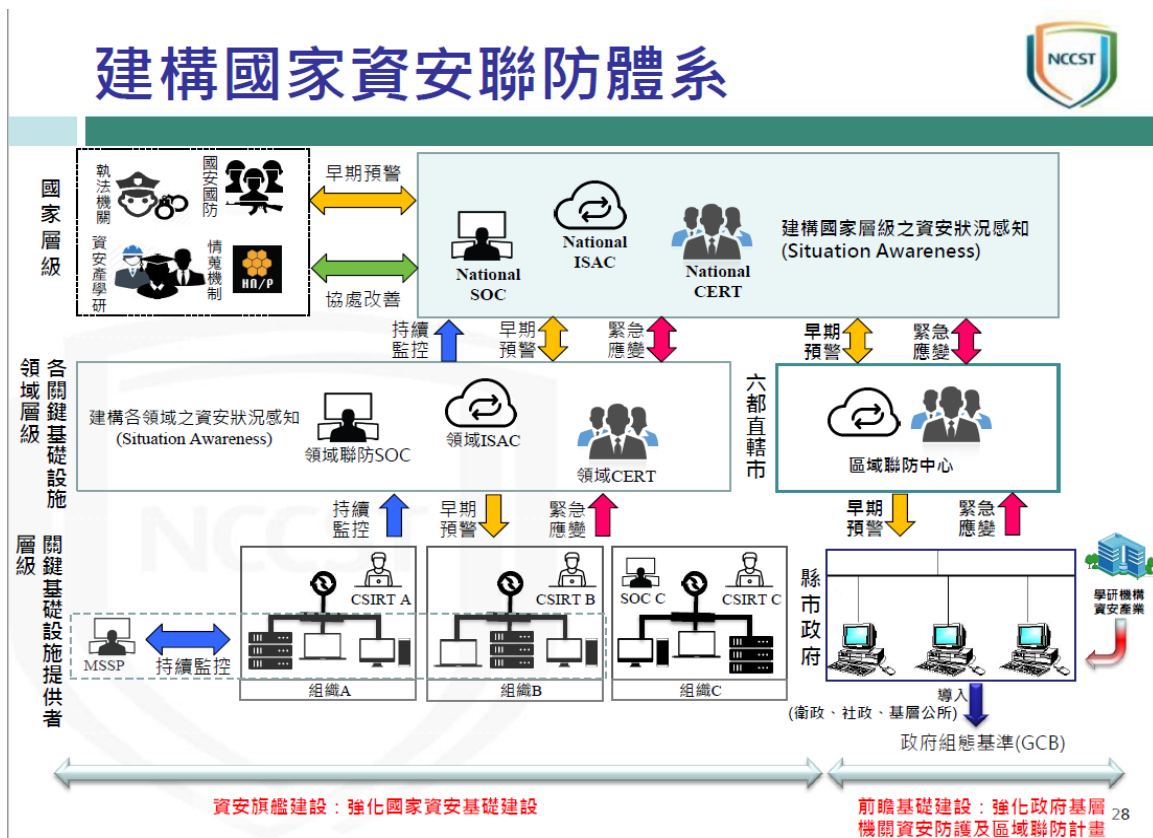


圖 3-2 建構國家資安聯防體系

資料來源：吳啟文，2017、資安威脅趨勢及防護策略

在各關鍵基礎設施領域層級中，金融監督管理委員會推動的 F-ISAC (Financial Information Sharing and Analysis Center，簡稱 F-ISAC)，提供情資共享的威脅預警，及應變協處與監控防護，參與會員數已達 376 家（至 109 年 8 月），這當中已包括國內所有的銀行與保險公司，同時也有證券、期貨、投信投顧業者，以及 Fintech 發展推動計畫中的業者加入(iThome，2020)，是故金融業應建立與 F-ISAC 串接之內外部情資蒐分析能力，上述為情蒐分析能力子構面。

金管會於 109 年依據行政院國家資通安全會報「國家資通安全發展方案」，規劃建置金融資安二線監控中心 (Financial Security Operation Center，簡稱 F-SOC)，藉由訂定與一線 SOC 協作之作業標準，包含事件資訊來源、事件分類與分級、事件資料格式與傳輸標準等，並據以推動與二線 SOC 之協同運作，以能即時有效關聯分析整體資訊安全風險，回饋金融機構加強資訊安全防護(金融資安行動方案，2020)，是故金融業應建立與 F-SOC 串接之監控處理應變能力，上述為偵測應變能力子構面。

金融業屬於關鍵基礎設施提供者層級，除應建立自己的電腦資安事件應變團隊 (Computer Security Incident Response Team，簡稱 CSIRT) 及建置上述能力以串接國家整體資安聯防體系外，亦應建立與自身所在集團、主管機關、同業、供應鏈、生態系之金融資安聯防體系，考量此議題國內仍在起步階段，多數金融業仍未有建立聯防機制，於未來數年將成為資訊安全單位之一大工作重點及負擔所在，故設定資安聯防機制子構面，以利與董事會成員溝通。

第四節、資安治理與資安績效

如第二章第四節所探討，因金管會係參考美國聯邦金融機構檢查委員會 (Federal Financial Institutions Examination Council，簡稱 FFIEC) 提供之資訊安全評估工具，訂定適用我國金融機構之評估方法，而該工具約須評估接近 500 項控制措施，經分析 NIST SP800-55 與 ISO 27004 與 FFIEC 資安評估工具之關聯性後，本研究依前述資安治理、資安韌性、資安防護三大主要構面所含治理架構、制度規範、資安素養、管理機制、風險識別、防護技術、情蒐分析能力、偵測應變能力、資安聯防機制、營運持續能力等十個子構面，提出適合向董事會成員呈報資訊安全績效之十項關鍵指標，如圖 3-3，分別為資安治理成熟度評估結果、內外部稽核缺失數量、資安人才證照比例、接受並通過資安培訓的人員比例、社交工程演練點擊率、專案如期如質如預算達成率、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量、資安事件通報查處回應成效、作業符合服務水準及復原時間目標。期望有利資訊安全權責主管以更簡明扼要之方式呈現資安績效。

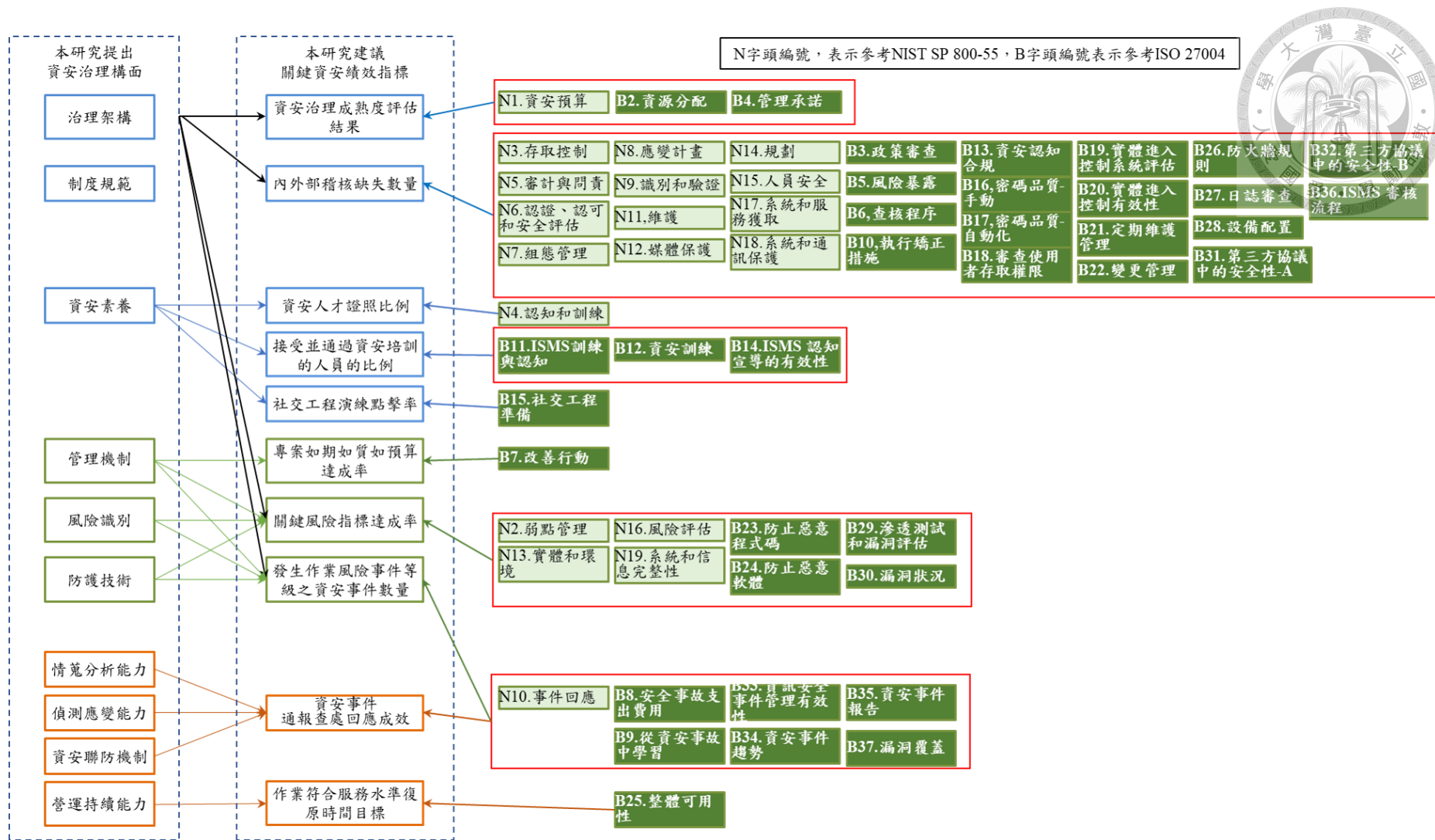


圖 3-3 資安治理構面與關鍵資安績效指標關聯圖
資料來源：本研究整理

在整體資訊安全治理績效上，以及治理架構子構面、制度規範子構面等二個子構面，皆可以透過資安治理成熟度評估結果、內外部稽核缺失數量、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量等四項指標評量績效。

建議使用資安治理成熟度評估結果作為指標，係考量其可以對應並覆蓋到 NIST SP 800-55 標準 1 項指標，以及 ISO 27004 標準 2 項指標，故簡化成一項，對董事會成員會更為明確且易於理解。

建議使用內外部稽核缺失數量作為指標，係考量其可以對應並覆蓋到 NIST SP 800-55 標準 12 項指標，以及 ISO 27004 標準 18 項指標，故簡化成一項，對董事會成員會更為明確且易於理解。

建議使用關鍵風險指標達成率作為指標，係考量其可以對應並覆蓋到 NIST SP 800-55 標準 4 項指標，以及 ISO 27004 標準 4 項指標，故簡化成一項，對董事會成員會更為明確且易於理解。

建議使用發生作業風險事件等級之資安事件數量作為指標，係考量其可以對應並覆蓋到 NIST SP 800-55 標準 1 項指標，以及 ISO 27004 標準 6 項指標，故簡化成一項，對董事會成員會更為明確且易於理解。

在資安素養子構面績效上，可透過資安人才證照比例、接受並通過資安培訓的人員的比例、社交工程演練點擊率等三項指標評量績效，可以對應並覆蓋到 NIST SP 800-55 標準 1 項指標，以及 ISO 27004 標準 4 項指標。

在管理機制子構面績效上，可透過專案如期如質如預算達成率、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量等三項指標評量績效。

在情蒐分析能力、偵測應變能力、資安聯防機制等三個子構面績效上，可透過資安事件通報查處回應成效這項指標評量績效；建議使用資安事件通報查處回應成效作為指標，係考量其可以對應並覆蓋到 NIST SP 800-55 標準 1 項指標，以及 ISO 27004 標準 6 項指標，故簡化成一項，對董事會成員會更為明確且易於理解。

在營運持續能力子構面績效上，可透過作業符合服務水準及復原時間目標這項指標評量績效，可以對應並覆蓋到 ISO 27004 標準 1 項指標



第五節、資安治理與管理框架建構步驟

如本章前述探討，本研究提出可依下列七項步驟建構完整資訊安全治理構面，其建構關係圖，如圖 3-4，說明如下：

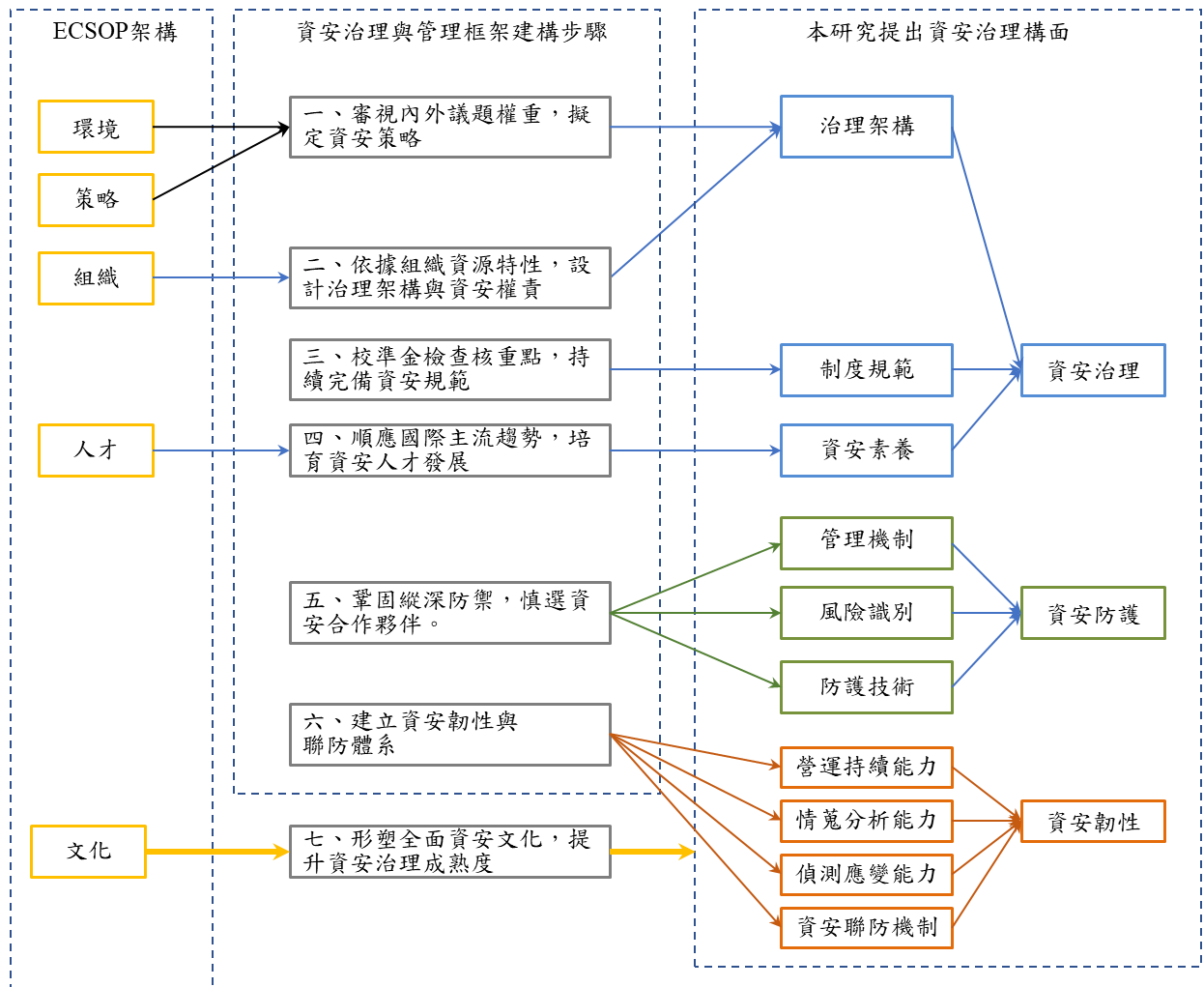


圖 3-4 建構完整資訊安全治理構面七步驟

資料來源：本研究整理



一、審視內外議題權重，擬定資安策略

策略管理的程序為先界定組織願景、使命、目標，接者分析內外部環境，其次形成策略，最後執行策略，並持續評估及修正策略；策略須校準目標，經審視內部優勢、劣勢與外部機會、威脅，並依據核心競爭力訂定，方能擬定有效之策略。

二、依據組織資源特性，設計治理架構與資安權責

企業內部雖未必設有資安長或資安官，但仍應有人或單位負起主導資訊安全的責任，其主要工作內容為建立資安相關政策規範或針對資訊安全問題提出解決方案，故可依據組織資源特性，如公司組織架構、人力資源、策略目標等狀況，設計負責推動資訊安全的單位，以協治理階層關注企業外部與內部影響資訊安全之議題變化，並擬定資安治理願景、目標、策略，上述運作機制即形成資安治理架構。

三、校準金檢查核重點，持續完備資安規範

資安治理需確保資安政策與相關規範，符合法令法規要求、營運服務水平、契約等外部或內部要求(CNS 27014, 2013)，而金管會確認金融業是否符合上述要求之機制主要為金融檢查，金管會檢查局於官網每半年會公布及更新金融檢查手冊，每年會發布金融檢查重點，並不定時會公告裁罰案件，金融業可透過審視自身資安規範與上述資訊之差異，及早因應，以降低查核缺失。

四、順應國際主流趨勢，培育資安人才發展

金融業者面對與日俱增的資安風險，將其轉換成對資安人才的殷切需求，這種現象已是現今全球金融業的普遍趨勢(李于宏，2021)，透過資安專責單位的設立，可讓資安人才更專注處理資安工作，並在企業中進行生涯規劃；透過薪酬條件優化，可吸引更多人投入金融業資安工作；透過自行培育資安人才，資安人員更能充分了解自身金融業務特性及風險，能提出更符合企業自身需求之資安對策。



五、鞏固縱深防禦，慎選資安合作夥伴

來自中世紀城堡的多層次防禦教導了我們在資訊安全上要有縱深防禦(Defense in Depth, 簡稱 DiD)的架構，而木桶原理(Cannikin Law)又告訴我們防禦最弱的地方會決定了整個防禦的真正強度，所以應識別出關鍵的風險，謹慎選擇合作夥伴，方能建立兼顧風險與成本的防禦機制。

六、建立資安韌性與聯防體系

在鞏固縱深防禦之後，隨著駭客攻防生命週期越來越短，金融業應用新興科技推展業務速度越來越快，管理層須認知到無法完成防範資訊安全事件發生，只能建立資安聯防體系，透過強化情資蒐集分享與資安事件監控分析能力，以及早發現異常，或於事故發生後以符合國際標準認可的方法迅速且正確的應變，以降低事件影響範圍，如此方可讓金融業化被動為主動，有效提升防護能力與資安韌性。

七、形塑全面資安文化，提升資安治理成熟度

唯有文化能夠順勢調整，變革轉型方能深化到位(李吉仁，2019)，筆者建議可利用 ECSOP 架構，將組織(O)與人員(P)當作推動資安治理的兩大引擎，並透過績效管理促進資安文化的形成。

第四章 建構符合資安治理與管理框架實作研究

一 金融業個案研究



如前章所述，本研究續以某金融業 A 公司為實例，描述其如何利用本研究所提出資安治理與管理框架，依循第三章第五節七項步驟將環境(E)、策略(S)、組織(O)、人員(P)、技術(T)、文化(C)等治理要件建構起來，除能符合主管機關對資訊安全專責單位的期許外，更能以國際標準為標竿，建立有效的資安治理體系，並進一步提高資訊安全治理成熟度，並驗證本研究所提出資安治理與管理框架實作的適宜性及可行性。

第一節、個案公司概况

一、個案公司概况

個案公司（以下簡稱 A 公司）為一家金融控股股份有限公司，旗下含銀行、人壽、產險、證券等主要子公司，除具有完整多元的金融產品與服務，且經營績效卓越，於 2017 年時，已連續多年位居市場領先地位，屬於金融業之標竿企業，其表現持續受到國內外媒體肯定，獲獎無數。

二、個案公司面對之資訊安全環境概況

(一) 外部環境

A 公司於 2017 年規劃整體資訊安全策略時，經參考國家資通安全發展方案，可知所面臨主要資訊安全威脅為資料欺詐或盜竊、大規模網路攻擊、關鍵資訊基礎設施無法正常運作、IoT 設備發動 DDoS 攻擊、行動裝置衍生的資料外洩事件、雲端運算攻擊工具、無人載具、暗網、深網等（行政院國家資通安全會報，2017）；另參考行政院國家資通安全會報技術服務中心提出之資訊安全威脅趨勢，可知使用者自攜資訊設備、駭客工具的成本降低與易於取得、人員的資訊安全意識不足、企業於海外展業初期的資訊安全的機制較弱、資訊安全人才明顯供不應求、現行金融業所使用資訊安全軟硬體多以國外大廠品牌為主、本國廠商之資訊安全產品較不具競爭優勢等，且隨著大量企業進行數位轉型、使用雲端服務、進行 O2O 整合，以及物聯網、人工智慧、5G 技術的發展，資訊安全的技術風險與日俱增（吳啟文，2017）。

(二) 內部環境

A 公司於 2007 年即透過導入資訊安全管理國際標準 ISO 27001 制度進行資訊安全治理，於 2017 年時，董事長下已設立有「資訊治理委員會」，目的在整合金控及其所屬各子公司之資訊治理，並督導建立健全的資訊治理文化與有效的資訊治理制度，此外亦設有資訊長之職務角色，但尚未設有資安長之職務角色，2017 年 2 月 24 日金融監督管理委員會第一次邀集本國銀行討論設置資訊安全專責單位後(金融監督管理委員會，2017)，當時 A 公司及其子公司皆尚未設有資訊安全專責單位，故資訊安全組織設計並未符合主管機關策略方向，如圖 4-1。

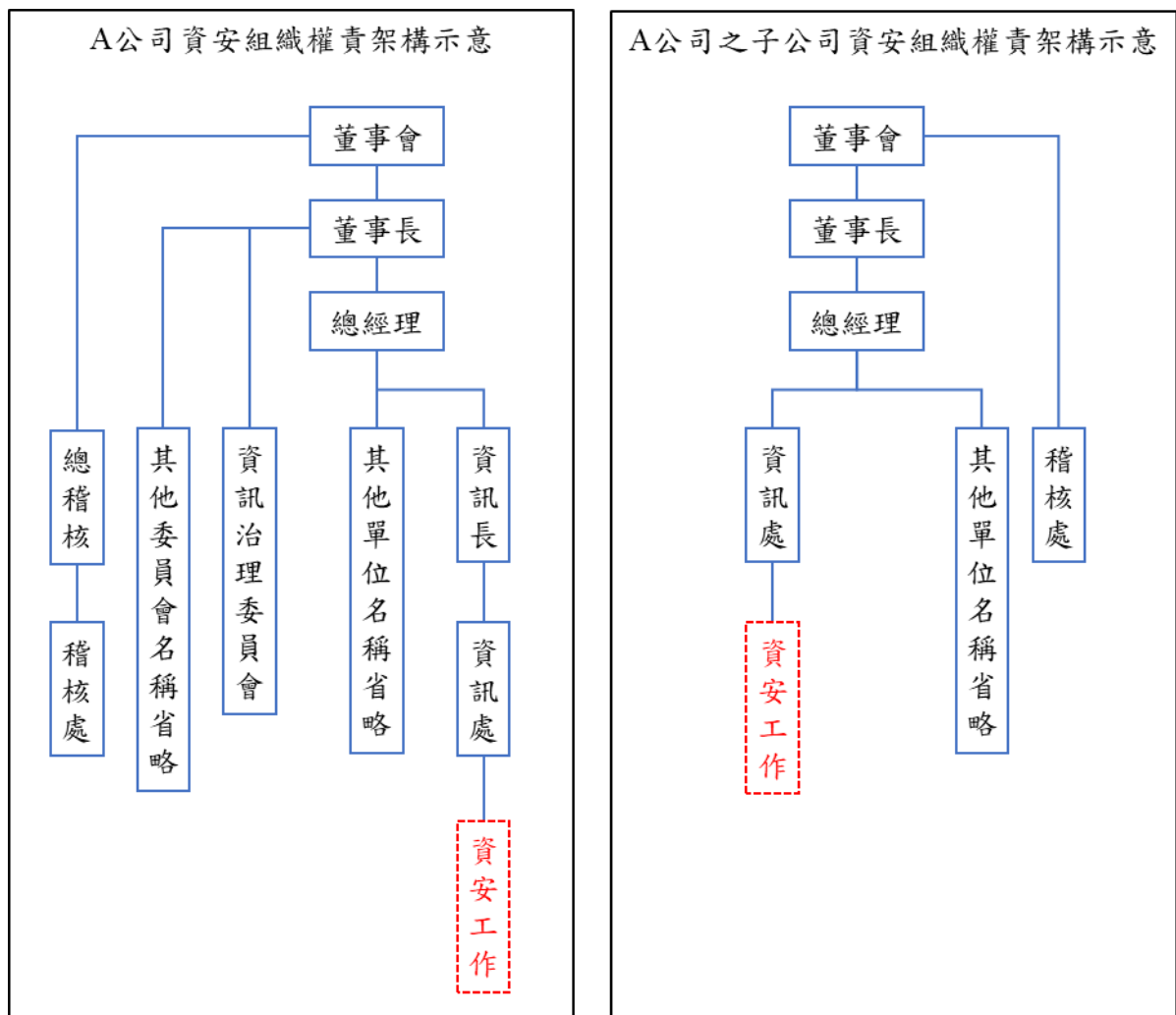


圖 4-1 A 公司與其子公司資安組織權責架構示意圖

資料來源：本研究整理

第二節、審視內外議題權重，擬定資安策略

以下依策略管理的程序，依序說明：一、界定資訊安全願景與目標；二、內部優勢、劣勢與外部機會、威脅分析；三、分析核心競爭力；四、形成資訊安全策略。



一、界定資訊安全願景與目標

策略係為目的、目標而存在，依據「資訊安全管理法」，資通安全指防止資通系統或資訊遭受未經授權之存取、使用、控制、洩漏、破壞、竄改、銷毀或其他侵害，以確保其機密性、完整性及可用性，故 A 公司將資訊安全目標訂為口語化之「符規、防毒、防駭、防呆、防漏、及早發現異常」，以利向董事會成員及內部員工溝通使用，而資安願景為呼應公司願景，設定為「成為亞洲金融業資安典範」，並採用第三章本研究所設計之資安治理三個主構面為架構，設定資安治理成熟度要達到國際標準企業水準、資安防護要做到無發生資安作業風險事件與受裁罰事件，資安韌性則通過 ISO 22301 國際營運持續管理標準並與金融資安資訊分享與分析中心及金融資安監控中心接軌等三大構面目標。

二、內部優勢、劣勢與外部機會、威脅分析

A 公司以平衡計分卡之流程、顧客、財務、學習成長四構面分析母公司若設立資訊安全單位之內部優勢、劣勢，以 PEST（政治、經濟、社會、科技）分析模型分析其外部機會、威脅。

（一）內部優勢

- （1）**流程面**：因各子公司網路與網路相連，且系統之間亦密切相關，故 A 公司應主動以母公司高度統籌建立聯防體系，較容易取得風險成本的均衡；在主管機關要求下，各公司皆已訂有明確的資訊安全制度規範，母公司可據以要求子公司，且依法母公司要求子公司並不會有管理權責之衝突。
- （2）**顧客面**：對子公司而言，母公司為一上市之公司，對外需對客戶維持企業整體品牌形象之一致性，故母公司可合理要求子公司配合母公司整體資安策略。
- （3）**財務面**：母公司結合各子公司需求，可辦理統籌採購，以降低整體採購成本。



- (4) **學習成長**：子公司資訊安全單位皆有大量資訊安全維運業務，若由較高階之母公司主導，較易運用資源並進行技術合作，讓子公司間互相學習並成長。

(二) 內部劣勢

- (1) **流程面**：加入資安管控會造成作業流程的改變，因子公司系統規模有不同差異，且大型子公司與小型子公司差異頗大，母公司在流程設計的考量無法兼顧子公司不同需求。
- (2) **顧客面**：母公司並非是直接對應到客戶的一線單位，故較難考量到顧客需求，而子公司較能快速佈署應用服務以因應顧客需求。
- (3) **財務面**：主管機關將很多資安的組織與流程的要求納入了法令法規之中，要降低風險必須付出相對應的成本，母公司若訂出一致資訊安全要求，原本風險較低且資源較少的子公司，反而會因此提高資訊安全資本及費用支出，但能下降的風險卻有限。
- (4) **學習成長**：母公司可統籌策略並訂定資訊安全基準，但母公司端人員若效率或效能不佳，或資安人員之專業能力不如子公司時，子公司人員反而會被母公司限制其學習成長速度。

(三) 外部機會

- (1) **政治**：母公司為上市公司，子公司發生資訊安全問題，主管機關會依情節追究母公司之連帶責任，且主管機關已明定設立資訊安全專責單位的相關規範須遵循。
- (2) **經濟**：資訊安全問題會影響獲利，例如 GDPR、個資保護皆有相關罰則。
- (3) **社會**：金融業最重要的是信任，發生資訊安全問題會影響母公司及子公司整體企業形象，影響消費者對公司的信任。
- (4) **科技**：物聯網、5G、AI、機器人等快速進步的技術，及各項新興科技衍生的資訊安全問題，已非單一公司既有之資訊安全人力所能負荷，需要集合更多人的力量，包含供應商、金融業生態圈一起努力才能解決。

(四) 外部威脅

- (1) **政治**：對子公司而言，子公司亦歸屬於主管機關下不同單位管轄，如銀行局、保險局、證期局，且各局對資訊安全的要求強度及資安控管方式之解



讀亦有所差異。

- (2) **政治**：子公司在法律上仍為單一法人個體，需各自負擔其公司治理、經營責任與資訊安全責任，母公司雖有權管轄，但最後責任仍由子公司自行負責，故仍須尊重各公司選擇。
- (3) **經濟**：資訊安全問題雖會影響獲利，但子公司對業務有其成本風險考量，母公司仍應尊重其成本風險考量。
- (4) **科技**：銀行、人壽、產險、證券等各子公司都有其不同業務特性，若使用獨有的系統技術，如 ATM、SWIFT，在母公司層級並未能實際接觸到該獨有業務，或受到專業能力之侷限，無法提供協助。

三、分析核心競爭力

有效的策略發展須建構在核心競爭力之上，A 公司先選定第三章本研究所設計之資安治理構面為架構，接著分析資安治理、資安防護、資安韌性三個主要構面（共含十個子構面）現況後，認為 A 公司有以下競爭優勢：

（一）資安治理面向整體發展均衡

A 公司與子公司於 2007 年即透過導入資訊安全管理國際標準 ISO 27001 制度進行資訊安全治理，其涵蓋範圍即包括母公司、銀行、人壽、產險、證券等不同業態子公司，與國內其他公司在資安治理最大的不同是「母公司與子公司從管理機制、技術架構、人才培育、流程設計，到績效考核皆校準一致性的資安策略，緊密聯繫運作」，形成一個強固的聯合防禦體系，資安治理面向整體發展較為均衡。

（二）母公司資訊安全人才職能完備

A 公司因母公司對資安要求一致性高，故母公司在資訊安全人員的職能完備程度上具有比同業及子公司更明顯的競爭優勢，例如在 2017 年盤點主管機關認可之資安專業證照，含 (ISC)² 的 CISSP、CSSLP、CCSP、SSCP，EC-Council 的 CEH、CHFI、ECIH、ECSA，ISACA 的 CISM、CISA，國際標準組織的 ISO 27001、ISO 22301、BS 10012 等證照，母公司 5 名資安人員具有 14 張證照，人員證照比例為 1 比 2.8，且資安工作相關歷練亦較完整，子公司 14 名資安人員則具有 17 張證照，人員證照比例為 1 比 1.2，故母公司已具完備之相關職能，可在子公司人力緊迫情況下，協助推展資安相關工作。



四、形成資訊安全策略

A 公司依據前述 SWOT 分析與核心競爭力分析結果，對應本研究提出資安治理構面之十個子構面訂出資訊安全策略如下，以利後續盤點資安治理所處現況與問題，擬訂對策及行動計劃。

- (一) 治理架構：設立資訊安全專責單位，推動資安相關工作。
- (二) 制度規範：校準金檢查核重點，持續完備資安規範。
- (三) 資安素養：建立制度化與專業化培訓，提升資訊安全人力素質。
- (四) 風險識別：強化風險管理機制，加快風險處理速度。
- (五) 管理機制：制定標準化技術設定，確定關鍵風險監控指標。
- (六) 防護技術：慎選資安合作夥伴，數據化呈現資安防護效益。
- (七) 情蒐分析能力：建立與 F-ISAC 串接之內外部情資蒐集分析能力。
- (八) 偵測應變能力：建立與 F-SOC 串接之自動化監控處理應變能力。
- (九) 資安聯防機制：建立金控集團、主管機關、同業、供應鏈、生態系之金融資安聯防體系。
- (十) 營運持續能力：導入 ISO 22301 管理制度，業務營運持續能力通過 ISO 22301 驗證。

第三節、依據組織資源特性，設計治理架構與資安權責

第二節提到在治理架構之策略為「設立資訊安全專責單位，推動資安相關工作」，因 A 公司各子公司業務特性與監管強度不同，且設立資訊安全專責單位後，原本資安與資訊在同一單位視為一體的角色，會轉換成具衝突性的兩個不同單位及角色，故 A 公司先增設資安長，再責成資安長去規劃資安治理架構與資安權責，擬定資安策略計畫，推動後續資安工作。

一、設立資訊安全專責單位

(一) 設立資安長及資安雙線報告機制

2017 年 2 月 24 日金融監督管理委員會第一次邀集本國銀行討論設置資訊安全專責單位後，A 公司為因應法規及主管機關監理要求，即增設資安長及資訊安全專責單位(資訊安全部)，由資安長督導、協調與協助子公司資安工作，期望符合主管機關要求及資訊安全國際標準規範，經策略分析後，除要求子公司設立資訊安全專責單位，並要求子公司於導入資安技術時，應先諮詢母公司資安單位意見，再由子公司權責主管參酌核可，且母公司資安長對子公司資訊安全專責單位具有考核建議權，此為雙線報告機制。

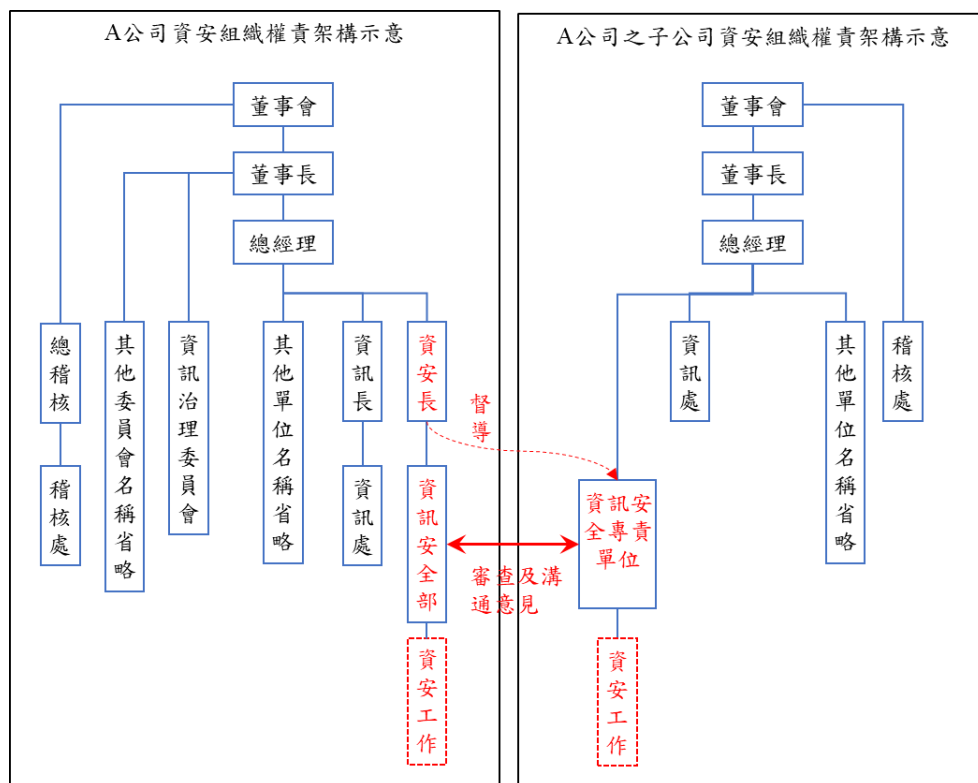


圖 4-2 A 公司與其子公司資安組織雙線報告關係

資料來源：本研究整理



(二) 設計子公司資訊安全專責單位

A 公司經整體考量後，將旗下子公司資訊單位與資訊安全單位分為圖 4-3 與圖 4-4 兩種關係，以利集團子公司資安運作有所依據。

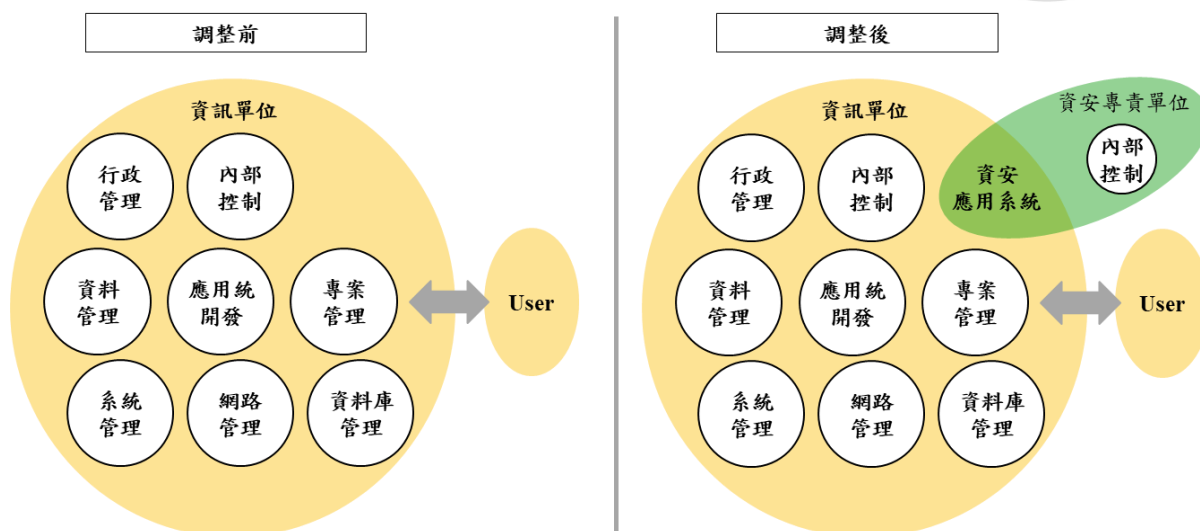


圖 4-3 資訊單位與資安專責單位的關係第 1 種

資料來源：本研究整理

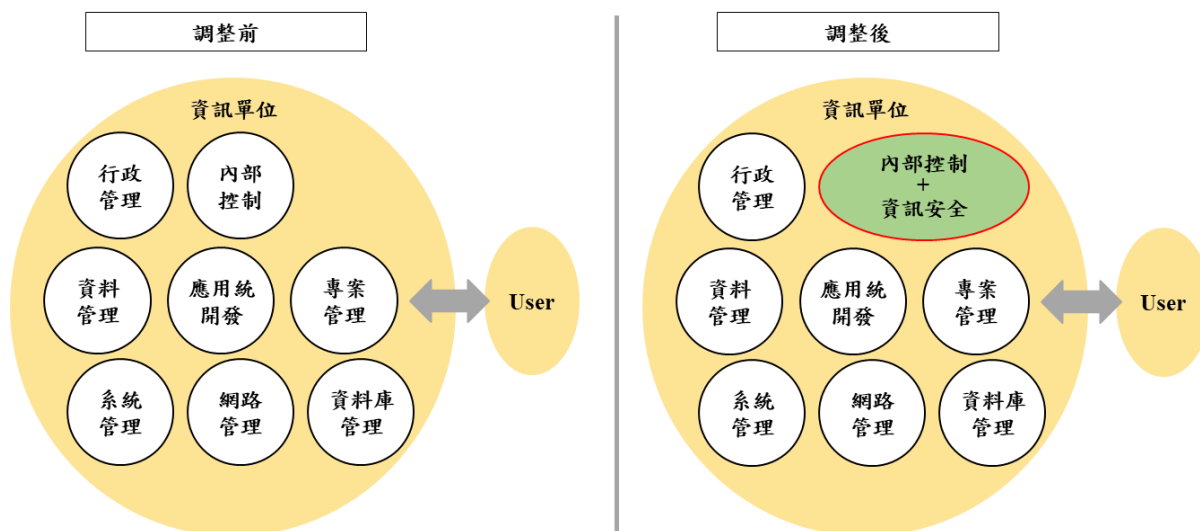


圖 4-4 資訊單位與資安專責單位的關係第 2 種

資料來源：本研究整理

其中銀行與人壽兩家子公司，因達到「金管會」制定之「金融控股公司及銀行業內部控制及稽核制度實施辦法」及「保險業內部控制及稽核制度實施辦法」中前一年度經會計師查核簽證之資產總額達新臺幣一兆元以上之門檻，故應設置具職權行使獨立性之資訊安全專責單位，並指派協理以上或職責相當之人擔任資訊安全專責單位主管，且基於業務推動與資訊安全控管平衡性，應將資訊安全專責單位獨立於資訊單位外且組織地位相當，不得兼辦資訊或其他與職務有利益衝突之業務，故將資訊安全業務從資訊單位下移出來，改由資安專責單位負責管理資安應用系統，如圖 4-3，但因資安專責單位人力較少，行政、總務等業務仍需由資訊單位繼續支援，且資訊安全應用系統之網路管理、系統管理、資料庫管理等作業亦仍由資訊單位提供服務，故雙方為交集之關係。

產險、證券等兩家子公司，因尚未達法令要求設定資訊安全專責單位之要件，故僅在原資訊單位範圍中，先將資安業務與原有內部控制業務聚集由單一科級單位負責，後續再視法令法規異動狀況進行調整，如圖 4-4。

二、設計資訊安全專責單位的權責職掌

企業若有策略調整，組織一定要跟著校準，才有機會產生預期的策略效果(李吉仁，2011)，故 A 公司在設計資訊安全專責單位的權責職掌時，首先參考行政院資通安全處公告之「資通安全責任等級分級辦法總說明」中所述資安應辦事項(如表 4-1)，設計資訊安全專責單位的權責職掌，因從上述規範可知以主管機關的角度，資安應辦事項含「管理面」與「技術面」兩大類型工作，其中「管理面」含辦理資通系統分級及防護基準、資訊安全管理系統之導入及通過第三方驗證、內部資通安全稽核、業務持續運作演練、資安治理成熟度評估等工作，「技術面」則含安全性檢測、資通安全健診、資通安全威脅偵測管理機制、政府組態基準、資通安全防护等事項；A 公司參考主管機關的角度進行內部分工，從原資訊單位將上述工作析離出來交由資訊安全專責單位負責，此種分工方式，除較易取得公司內部之認同，亦有利於與主管機關溝通設計考量。

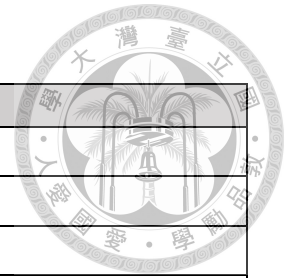


表 4-1 資安專責單位應辦事項

制度面向	辦理項目	辦理項目細項
管理面	資通系統分級及防護基準	
	資訊安全管理系統之導入及通過第三方驗證	
	資通安全專責人員	
	內部資通安全稽核	
	業務持續運作演練	
	資安治理成熟度評估	
技術面	安全性檢測	網站安全弱點檢測
		系統滲透測試
	資通安全健診	網路架構檢視
		網路惡意活動檢視
		使用者端電腦惡意活動檢視
		伺服器主機惡意活動檢視
		目錄服務器設定及防火牆連線設定檢視
	資通安全威脅偵測管理機制	
	政府組態基準	
	資通安全防護	防毒軟體
		網路防火牆
		電子郵件過濾機制
		入侵偵測及防禦機制
		應用程式防火牆
		進階持續性威脅防禦措施

資料來源：資通安全責任等級分級辦法總說明及逐條說明，2018、本研究整理

第四節、校準金檢查核重點，持續完備資安規範

考量國內金融業經歷 2016 年 7 月第一銀行自動提款機被國際駭客盜領，2017 年 5 月 12 日勒索病毒 WannaCry 攻擊，2017 年 1 月第一次證券商集體遭到 DDoS 攻擊勒索，2017 年 10 月遠東商業國際銀行發生國際匯款系統 SWIFT 被駭客入侵盜轉 18 億元等事件之後，主管機關對金融業之資訊安全要求隨著資安事件層出不窮而越來越高，且許多尚未明確訂定於正式規範之資安要求，主管機關亦會透過金融檢查提出意見，以驅動金融機構對資安的重視；如個案公司概况所述，A 公司為金融業之標竿企業且已導入 ISO 27001 資訊安全管理國際標準多年，故資訊安全相關規範已有一定之完整度及落實度，但面對金檢議題，仍需超前部署，故透過「校準金檢查核重點，持續完備資安規範」步驟，以母公司的角色邀集各子公司根據金檢檢查項目、資安管控重點、常見內外部稽核缺失以及同業裁罰作為輸入項目，先行分析是否存在類似狀況？是否可能有稽核缺失？是否有相關資安風險？落實程度？並分析歸納其態樣及根因，預判可能缺失，研擬因應方案，期望持續完備制度規範子構面，避免金檢缺失與裁罰。

A 公司在訂定集團資訊安全規範基準時，特別加強與子公司的溝通協調，在審慎評估各公司狀況之後，方制定最低資訊安全基準與流程原則，目的在兼顧各公司業務與風險屬性，求同存異保留各自業務運作之彈性，讓子公司可自行依業務需求設計流程，以快速因應顧客需求。

A 公司先以專案模式進行上述工作，專案完成後，由母公司資安專責單位於資訊治理委員會呈報成效，並轉化為日常維運機制，如下：

- 一、將金檢檢查項目、資安管控重點、常見內外部稽核缺失，與現行資安管理審查會議「稽核缺失分析」議題整合。
- 二、將已發生之所有同業裁罰項目列入自行查核項目，於每次自行查核前審視並更新。
- 三、結合現有稽核與法遵同業裁罰通報審視機制，於發生同業裁罰案時，及時檢視相關作業內容是否有符合相關樣態，並作調整。
- 四、建立資安稽催管理機制，強化各項定期作業(如系統弱點評估、資安評估等)與不定期作業(如因應外部情資之回應、系統上下線安控作業等)之稽催效能，由資訊單位權責主管於例行營運會議檢討。

五、將新增修訂資訊安全規範之作業，納入母公司與子公司資訊安全定期例會辦理，任何資訊安全規範新增修訂，皆須先取得母公司與子公司資安專責單位的共識，再由各公司資安專責單位去負責取得所代表公司內部共識後，最後則以母公司名義正式發文請各子公司遵照辦理。



第五節、順應國際主流趨勢，培育資安人才發展

一、資安人才發展困難與對策

A 公司評估在資安人才發展上遇有資安專業人力有限、資安人才招聘困難、資安人才流動率高、資安訓練相較一般訓練成本高等困難，並擬定相關對策。

(一)資安專業人力有限

如本章「第二節、審視內外議題權重，擬定資安策略」中所述，A 公司身為母公司在資訊安全人員的職能完備度上具有比同業及子公司更明顯的競爭優勢，故在子公司人力緊迫情況下，可協助推展資安相關工作，並同步協助子公司資安單位爭取擴編人力。

(二)資安人才招聘困難

由於企業受到資安監理強度的加強加廣加深，導致資安人才稀缺，招募困難，故 A 公司積極營造重視資安的口碑，打造友善的資安工作環境，並透過與政府、學校、訓練機關合作，擴大徵才管道，設計較具市場競爭力之薪酬制度，搭配於招募時放寬錄用資格與條件，於錄取後再進行內部培訓等措施以吸引人才。

A 公司雖已有重視資安之文化，惟金融業屬於對資訊安全採取高強度控管之行業，故相較於在其他行業工作，許多資安人才會覺得在金融業的工作有文化適應上的困難，且隨著資安產業蓬勃發展，資安人才未必要投入金融業做資安工作，但金融業亦相對較其他產業更願意投入資源做資訊安全，故選材時，A 公司儘量以人格特質選材，並以較為充足的資安資源為吸引條件，以提高人才就業意願。

(三)資安人才流動率高

在高強度資安控管之下，若內部主管或風控、稽核等二、三道防線人員資安專業能力不足時，常會讓資安人才有外行指導內行的感受，亦增加資安人才挫折感，提高人才流動率，故應於內部推動資安主管及二、三道防線人員取得資安相關證照，降低彼此溝通之隔閡，降低人才流動率；同樣的，金融業較其他產業更為充足的資安資源投入，會是降低資安人才流動率的一個關鍵要素。

(四)資安訓練相較一般訓練成本高

公司對每位員工皆編列有基本教育訓練預算，惟通常資安訓練較一般企業訓練費用高，基本預算通常無法滿足需求，故應另訂定訓練補助、證照獎勵等相關規範以支持資安訓練，方有利自行培育資安人才。





二、資訊安全職能的類型

A 公司在資訊安全職能的設計上，首先考量需與國家資安策略、資安人才培訓體系介接，以有利內部溝通與後續發展。

在國家資安策略面向，參考行政院國家資通安全會報資訊安全人才培訓服務網，將資訊安全專業人力職能，依其業務職掌，分為策略面、管理面、技術面 3 個面向，及共通職能與專業職能 2 個層次，如表 4-2。

表 4-2 資安專職人力職能

面向	策略面	管理面	技術面
共通職能	具備資通安全基本認知及資通安全法規認知		
專業職能	- 具資安策略規劃與推動能力 - 具資安管理業務審查能力 - 具資安資源協調規劃能力 - 具資安稽核與管理能力 - 具績效與成果監督能力	- 具資安管理機制規劃與維運能力 - 具資安資源配置與管理能力 - 具資安風險與控制評估能力 - 具處理通報應變作業能力	- 具網路管理能力 - 具事件處理能力 - 具資安檢測能力 - 具系統管理能力 - 具情資分析與分享能力

資料來源：行政院國家資通安全會報技術服務中心資安人才培訓服務網，2018

在資安人才培訓體系面向，經濟部工業局資安網路學院，依據產業資料蒐集及專家職務訪談結果，分析資訊安全專職人才職能，將資訊安全人才分為三類型：政治型、應用型、技術型，其主要職責如表 4-3。

表 4-3 產業資安專業人才主要職責

類型	政治型	應用型	技術型
角色	- 資安長 - 資安政策制定人員	- 資安經理人 - 資安管理/規劃人員	- 資安技術人員 - 資安工程師
工作描述	主掌企業資訊安全與風險管理業務、制定相關資安政策與戰略部署	建立符合法規與組織安全需求之資訊安全架構，並維運組織資訊安全相關活動	負責企業系統、網路與資訊安全的日常維運與相關防護工作
主要職責	- 資安政策與資源配置 - 資安治理與監督	- 資安架構規劃 - 資產與風險管理 - 資安法規遵循 - 教育訓練	- 網路與通訊安全 - 系統與程式安全 - 資安服務維運 - 資安防護監控 - 事故應變處理 - 新興科技安全

資料來源：經濟部工業局 108 年度資安專業人才職能分析報告，2019、本研究整理

三、資訊安全專責單位人才類型

A 公司為建構資安治理、資安防護、資安韌性三大構面，依據本章第三節資訊安全專責單位的權責需求，參考行政院國家資通安全會報之資訊安全專業人力職能、經濟部工業局產業資安專業人才主要職責等資料，在內部定義資訊安全專責單位人才類型應分為資安治理、資安評估、資安維運、資安監控分析等四類型人員，其人才需求與人力職能、職責對應關係如圖 4-5。



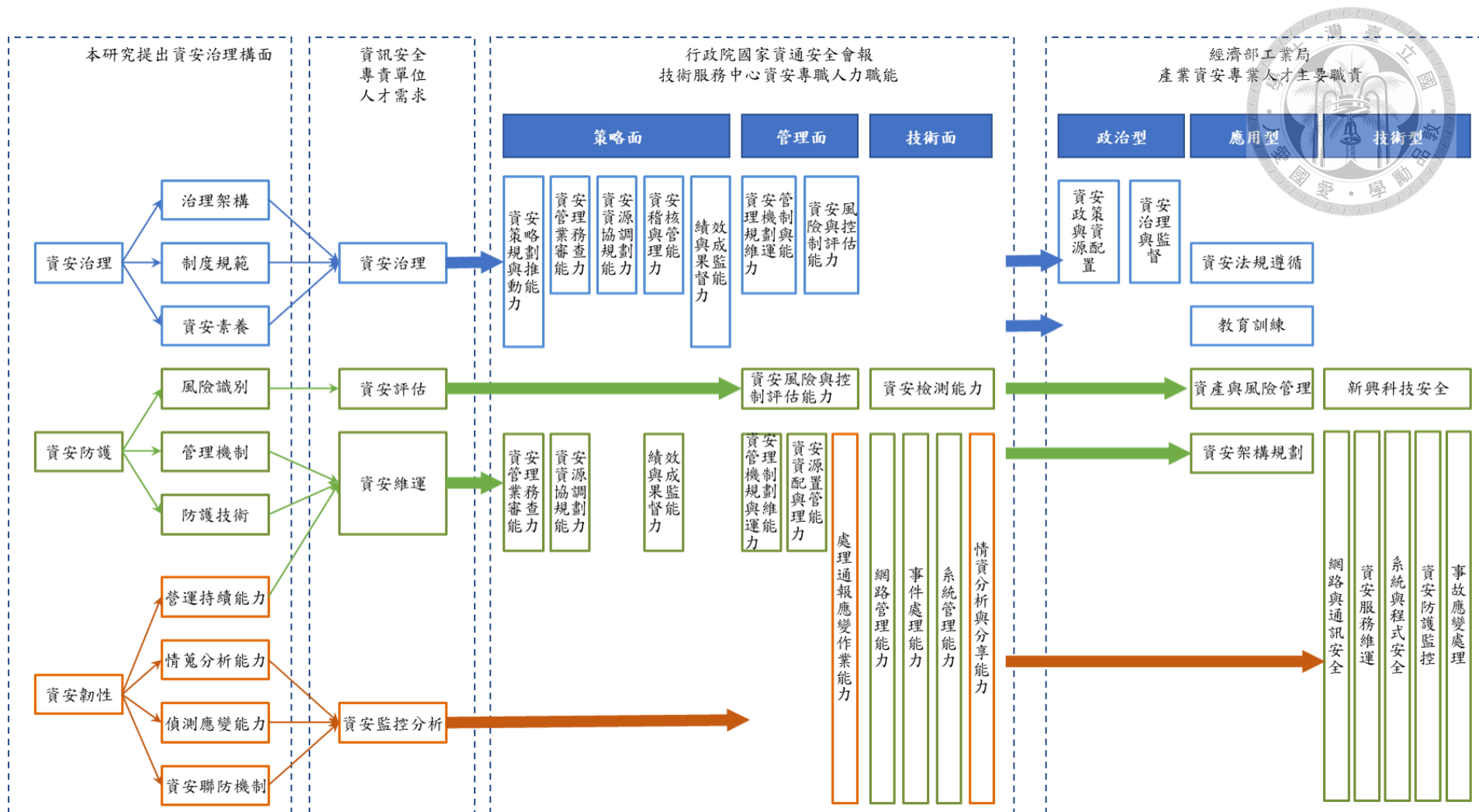


圖 4-5 資安人才需求與職能職責對應關係

資料來源：本研究整理



四、資安素養培育對策

(一) 資安人員資安素養

A 公司經分析資訊安全專責單位需求與挑戰、資安人才職能與職責後，確立母公司須培養具優秀策略規劃與資安管理能力之高素質的資安人才，子公司端須培養具備能與母公司溝通策略，並根據子公司業務特性進行調適並具資安防護實務能力之資安人才。

建立資訊安全專責單位後，短期可互相支援以降低人力缺口，並讓人力較充足之公司支援人力不足之公司以提升後者之資訊安全強度，長期則補助資訊安全人員進修或增加獎勵，以提昇全體資訊安全人力素質。

A 公司參考行政院國家資通安全會報資通安全專業證照清單，先找出符合國內主管機關要求證照、A 公司主要海外據點所在地(香港)之主管機關要求證照、國際資安證照排名調查前十名等相關證照(如表 4-4)，再將其訂定為內部資安人員應具備資格及證照，除要求內部人員於到職一年內依其職務類別需至少取得一張相關證照外，亦做為對外徵才之優先考量，並透過獎勵或補助，提升同仁學習進修之動機。

表 4-4 金融業資安證照規範要求與證照排行相關參考資料

證照名稱	國內-金融機構 辦理電腦系統資 訊安全評估辦法	國內-政府機構資 通安全責任等級 分級作業規定	國外-香港金融管 理局網路防衛計畫	國外-國際資安證照 排名調查(前 10 名)
CISSP	●	●	●	●
CISM	●	●	●	●
SSCP		●	●	●
CEH	●	●	●	●
ECSA			●	●
ECIH	●			
CISA			●	●
ISO 27001	●	●		

資料來源：本研究整理

上述作法，可順應 A 公司「成為亞洲金融業資安典範」之資安願景需求，建立了制度化培育資安人才之機制，有利吸引符合國際主流趨勢要求之資安人才，於內部溝通時，亦可立即對應策略需求，有利與管理高層溝通以取得支持及資源。

金管會於 2020 年 8 月發布「金融資安行動方案」於新聞稿中提到，為強化金融機構資安人才能力建構，將依據金融資安職能需求訂定人才培訓地圖；協調周邊單位開設金融資安人才養成專班，與科技公司合作，充實師資及課程，透過產學合作、跨業合作，培育跨領域人才；並鼓勵金融資安人員取得國際資安證照，以培訓符合實務需要的資安人才。以 A 公司狀況，對於主管機關上述策略議題，其中訂定人才培訓地圖、開設金融資安人才養成專班、培育跨領域人才等，A 公司僅能扮演配合的角色，故 A 公司透過「建立制度化與專業化培訓，提升資訊安全人力素質」之策略，將重點放在「鼓勵金融資安人員取得國際資安證照，培訓符合實務需要的資安人才」，以有效校準並符合主管機關要求。

(二) 一般人員資安素養

依據金融控股公司及銀行業內部控制及稽核制度實施辦法，銀行業總機構、國內外營業單位、資訊單位、財務保管單位及其他管理單位之人員，每年至少須接受三小時以上資訊安全宣導課程；依據保險業內部控制及稽核制度實施辦法，保險業總機構、國內外營業單位、商品開發管理單位、資金運用單位、資訊單位、資產保管單位及其他管理單位之人員，每年至少須接受三小時以上資訊安全宣導課程；依據證券暨期貨市場各服務事業建立內部控制制度處理準則，使用資訊系統之從業人員，每年應至少接受三小時以上資訊安全宣導課程。故 A 公司以母公司身分統籌辦理母公司與銀行、人壽、產險、證券等子公司全體同仁資訊安全線上教育訓練至少三小時，可統一管控教育訓練品質，並發揮資源共享，降低管理成本之效益。

A 公司參考勞動部推動之人才發展品質管理系統(Talent Quality-Management System，簡稱 TTQS) 建立內部教育訓練機制，而 TTQS 使用柯氏四級培訓評估模式(Kirkpatrick Model)來評估一般人員資訊素養，此評估模式係於 1959 年由 Donald.L.Kirkpatrick 提出，目前已廣泛應用於培訓領域。

A 公司應用 Kirkpatrick Model，透過資安訓練提升人員資安素養，以達成公司資安願景與目標，作法如下：



- (1) **反應層次：**以「教育訓練滿意度調查」檢測受訓者對訓練內容、訓練時間、訓練方法、訓練效果的滿意程度。
- (2) **學習層次：**以「教育訓練課後考試」檢測受訓者對訓練內容的理解與掌握程度。
- (3) **行為層次：**以「社交工程演練」檢測受訓者是否能應用所學，改變行為，降低點擊社交工程演練信件的機率，以確認訓練成效。
- (4) **績效層次：**為達到 A 公司資安防護要做到「無發生資安作業風險事件與受裁罰事件」之目標，透過「資安事件根因與人員疏失的關聯性分析」，檢視公司整體是否因為資安素養的提高，而有效降低因人員疏失發生資安事件的機率。



第六節、鞏固縱深防禦、慎選資安合作夥伴

A 公司在設計資訊安全縱深防禦架構時，首先會識別出風險在哪裡，接著在考慮成本與風險的平衡下，選擇適當的防護技術、管理機制，彼此互相搭配去控制風險，並建立其績效評量方式，透過資安風險事件發生的原因來判斷，當發生資安事件時，反過來檢視這個事件是否在當初風險識別有識別出來，是否完整控管風險，最後透過定期檢視現有資安合作夥伴之服務品質與績效，慎選合作夥伴並汰弱留強，並透過專案如期如質如預算達成率、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量等三項指標呈現，以利董事會及總經理能認同資安防護的投資成效。

一、風險識別

A 公司因已導入資訊安全管理國際標準 ISO 27001 制度，已建立風險評鑑機制，透過審視及評估資訊資產價值、弱點、威脅、控管措施，計算出風險權值，除了擬定風險管理計畫進行改善外，並訂定出每月關鍵風險指標進行監控，如高風險資訊安全弱點未管控數量為 0、全公司電腦病毒或蠕蟲攔截次數小於 1%、資訊安全事故為 0 等目標。

A 公司已導入弱點掃描、黑箱、白箱、APP 檢測、滲透測試等風險識別技術，但亦持續關注新興技術衍生之資訊安全威脅，配合新技術如容器技術、雲技術的引進，持續建立新的資安檢測機制。

隨著資訊設備與物聯網設備數量增加，主管機關資安監管強度增加，A 公司掃描作業及弱點管理數量以現行人工作業方式控管已面臨作業瓶頸，故導入風險弱點管理系統以整合管理不同弱點掃描工具，改善人工作業效率，並使用外部自動化風險評估服務，以攻擊者角度，透過自動化蒐集公開數據、網路誘捕機制與整合威脅情資、弱點搜尋引擎分析機制，計算出風險係數，建構從企業的內部、外部同時進行風險識別與管理機制，並有利即時掌握對外暴露之風險並與同業比較。



二、管理機制

A 公司已建立符合資訊安全管理國際標準 ISO 27001 與 NIST CSF 之管理機制。及作業流程，如資訊資產管理、事件及問題管理、作業風險通報、數位證據保全、安全的軟體開發生命週期(Secure Software Development Life Cycle，簡稱 SSDLC)等。

A 公司在資訊安全治理或管理層級相關會議，設計了資訊治理委員會、母公司與子公司資安例會、資訊安全管理審查會議三種。

透過資訊治理委員會，審核整體資訊治理策略、架構及制度，督導子公司整體資訊治理事宜，審視資訊治理定期報告，檢討重大資安事件。

透過母公司與子公司資安例會，可共同討論資安防禦對策、評估資訊安全技術對策與控制措施、研擬法令法規修訂因應方案、分享資安管理及事件通報查處經驗、分享資安情資、與外部廠商進行交流、檢視合作夥伴之服務品質與績效等；藉由資安例會，母公司亦可檢視子公司資安執行狀況，並促使各公司相互交流，共同吸取外部新知以持續精進管理機制。

透過資訊安全管理審查會議，進行定期風險評鑑，審視內外稽核查核議題、利害關係人回饋議題，共同研擬、審視、討論已知風險與潛在風險之改善計畫。

三、防護技術

A 公司於採用資安防護技術時，則依據前述資訊安全管理國際標準 ISO 27001 要求、風險評鑑的結果、關鍵風險指標等因素設計，並參考 NIST CSF、「台灣資安市場地圖」與「台灣資安產品及服務通過能量登錄服務機構地圖」去評估該資安技術使用時機、定位及後勤支援能量，以利與高階主管溝通技術需求之合理性、可行性及必要性。A 公司使用狀況整理如表四-5，而表中所列「有」使用並不侷限於台灣資安市場地圖中所列出之資安產品與服務，表中所列「無」使用，亦非 A 公司不會使用，只是仍在評估導入之適當時機；A 公司對防護技術相關議題，會依風險識別結果與管理機制的配套需求，經評估成本、效益、技術成熟性、國內同業使用狀況等因素，然後選擇自行建置、委外服務、以類似技術替代或以其他補償性措施等方法，來解決表 4-5 所列技術擬解決之客戶痛點。

表 4-5 A 公司採用資安產品與服務與 NIST CSF 5 大功能對應關係

項次	台灣資安市場地圖資安產品與服務	A 公司 有無使用	對應 NIST CSF 5 大功能				
			識別	防護	偵測	回應	復原
1	Advance Threat Protection	有		○	○		
2	Application Security Testing	有	○		○		
3	Authentication	有		○			
4	Cloud Security	有	○	○	○	○	○
5	Container Security	有	○				
6	Data Leak Prevention	有		○			
7	DDoS Protection	有		○			
8	DNS Security	有		○			
9	Encryption	有		○			
10	Endpoint Detection & Response	有			○	○	
11	Endpoint Prevention	有		○			
12	Firewall Management	有		○			
13	GCB	有		○			
14	Identity Governance	有		○			
15	Managed Security Services	無			○	○	
16	Messaging Security	有		○			
17	Mobile Security	有		○			
18	NAC	有		○			
19	Network Analysis & Forensics	有			○	○	
20	Network Firewall	有		○			
21	OT Security	有		○			
22	Penetration Testing	有	○		○		
23	Privileged Access Management	有		○			
24	Risk Assessment & Visibility	有	○				
25	Secure File Sharing	有		○			
26	Security Analytics	有	○		○	○	
27	Security Awareness & Training	有		○			
28	Security Incident Response	有				○	
29	Security Information and Event Management	有			○		
30	SOAR	無		○	○	○	
31	Threat Intelligence	有	○				
32	WAF & Application Security	有		○			
33	Web Security	有		○			

資料來源：本研究整理



第七節、建立資安韌性與聯防體系

一、情蒐分析能力

知己知彼，百戰不殆，要掌握攻擊者的情資，知道敵人的動態，才能有效準備因應，就像防疫要因應疫情的變化，不斷調整防疫對策與作為一樣；A 公司及其子公司在收到 F-ISAC、政府資安情報、資安新聞等外部情資通報或遇到內部資安事件後，常會需要再以人工分析調查情資之完整度、準確度及適當使用方式，方能針對會實際威脅企業的資安情資(例如駭客威脅、勒索病毒威脅等)，進行後續利用或分享，故 A 公司擬定「建立與 F-ISAC 串接之內外部情資蒐集分析能力」之策略，建立標準作業流程，並以整體資安協同防禦的角度，建構一整合平台，整合各開源及商用的情資來源，透過 API 介面，自動將各公司偵測疑似異常的事件資訊比對威脅情資，縮短資安人員分析調查時間，並交叉分析各公司回報之資安數據，在戰情室大型螢幕儀表板(Dashboard)呈現即時統計資訊，提供主管透過視覺化界面快速掌握母公司與子公司資訊安全事件關聯趨勢，並發揮內部快速分享資安情資之效益。

二、偵測應變能力

A 公司原已建置了資訊安全管理平台，蒐集各系統日誌，關聯偵測與分析內外部資訊安全事件，發布警示及輔助事件調查，並可自動化分析與偵測具針對性、未知的進階持續威脅攻擊(Advance Persistent Threat，簡稱 APT)，惟在資訊安全管理平台過濾分析大量數據後，仍會有大量可疑事件及警示報表需要有經驗的資安人員再以人工分析確認，故參考金融資安行動方案所建議「研議導入 AI 分析機制，進行警訊及事件關聯分析，以自動化與智能化提升情資分析動能、即時將攻擊情資回饋至第一線資安監控主動防禦」，A 公司導入應用 AI 分析端點活動，整合威脅情資，自動化並即時偵測回應異常事件之「端點偵測回應及自動事件調查系統」，以期更快找出攻擊入侵事件以更快速回應，將現行「透過鑑識團隊 3 至 5 日完成分析調查」，強化為「系統自動在事件發生 60 分鐘內完成告警與分析」。

A 公司為驗證偵測應變能力，定期進行紅隊演練，透過外部專家模擬駭客組織的攻擊方式(扮演紅隊)並由各公司資安單位負責防守與阻擋(扮演藍隊)，於演練後，由外部專家提供其入侵利用的途徑及修補改善建議，除可測試系統與網路的安全強度，亦藉此強化整體資訊安全應變及防禦能力，掌握駭客攻擊重點與脈絡，修補防禦措施。

A 公司現行亦持續關注及配合 F-SOC 金融資安監控中心之推動時程，建立可串接 F-SOC 之自動化監控處理應變能力，以利後續將資訊安全事件在去識別化後，自動通報到 F-SOC，符合主管機關資安監理要求。

三、資安聯防機制

金管會從 2016 年開始推動建立金融業資安聯防體系，2017 年成立「金融資安資訊分享與分析中心」，期望協助金融產業提升資安防護水準、強化金融業資安聯防、預防資安事件擴大(蔡福隆，2018)，2020 年亦規畫建置「金融資安監控中心」及訂定資安監控作業標準，推動金融機構與「金融資安監控中心」協同運作聯防機制，因此，金融業應建立可對應或接軌整體聯防機制之系統及能力。

除了金融業的資訊安全情資、資訊安全事件分享，更進一步，A 公司要做到建立集團與主管機關、同業、供應鏈、生態系之金融資安聯防體系，這個聯防體系，關鍵點還是在透過資安情資與資安事件的交流分享，以利體系中的成員能互相學習經驗、及時因應、調整防禦對策。

四、營運持續能力

A 公司於多年前即透過導入營運持續管理國際標準 BS 25999，建立了災難應變與復原的實作能力，包含人員疏散、危機決策、利害關係人回應以及異地辦公室、線路與資訊系統的復原準備皆有了全盤性的規劃，以期能在災害發生時持續提供客戶服務；隨著國際標準的演變，BS 25999 已經在 2012 年被國際標準組織採認，成為新的持續營運國際標準 ISO 22301，故 A 公司亦順應趨勢，另訂定通過 ISO 22301 營運持續管理國際標準的驗證之目標，透過此驗證過程，持續精進營運持續能力，以在發生影響業務的事件時(包含資安事故)，能適時啟動應變及復原程序，有效降低事件對營運的衝擊，確保公司服務的持續性。

第八節、形塑全面資安文化，提升資安治理成熟度

A 公司透過建構資安治理、資安韌性、資安防護三大主要構面及其所含治理架構、制度規範、資安素養、管理機制、風險識別、防護技術、情蒐分析能力、偵測應變能力、資安聯防機制、營運持續能力等十個子構面，再加上績效考核來建立重視資安的企業文化，並提升資安治理成熟度。

一、對治理層級人員

為讓治理層級人員易於掌握整體資安狀況，A 公司參考美國國家標準技術研究所發布之 NIST SP800-55 資訊安全績效量測指南、ISO 27004 資訊安全管理量測標準及國內相關研究資料，及資安治理、資安韌性、資安防護三大主要構面所含治理架構、制度規範、資安素養、管理機制、風險識別、防護技術、情蒐分析能力、偵測應變能力、資安聯防機制、營運持續能力等十個子構面，設計出適合向董事會成員呈報資訊安全績效之十項關鍵指標，分別為資安治理成熟度評估結果、內外部稽核缺失數量、資安人才證照比例、接受並通過資安培訓的人員比例、社交工程演練點擊率、專案如期如質如預算達成率、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量、資安事件通報查處回應成效、作業符合服務水準及復原時間目標。透過績效指標的量化與簡化，讓治理層級人員能以更簡明扼要之方式掌握資安狀況、資安治理成熟度及評估資安績效。

二、對全體人員

A 公司實施全員必修之資訊安全相關訓練，包括資訊安全宣導、社交工程演練宣導、個人資料保護等，以持續強化員工道德與法治觀念，員工績效考核之個人目標設定有「內稽內控作業」、「法令遵循執行考核」、「稽核查核缺失」、「作業風險事件」等指標，以衡量員工在內稽內控、法令遵循及作業風險之表現，透過在各面向的不斷努力務求將誠信與道德價值在企業內生根，促進企業永續發展。

為強化同仁遵循、重視業務執行過程，以符合公司各項內部控制制度，公司制訂「員工疏失管理準則」、「內控違失案件人員責任歸屬與懲處準則」，以定義疏失、懲處責任之歸屬、權責界定、懲處等，將風險管理貫徹於同仁工作中，引導同仁重視交易與行政作業面之風險防制。

為引導同仁校準資訊安全願景與目標，A 公司於各單位績效考核中增加「資訊安全績效指標」，指標含「部門人員觸發防毒程式告警為 0 件」、「部門人員於每次社交工程演練點擊郵件連結或開啟附件人數比例低於 2%」、「資安事故發生件數為 0 件」、「部門人員年度資安/個資訓練未完訓(排除因合理原因無法受訓者)人員為 0 人」等，以評核各單位資安執行成效。

三、對資訊安全專責人員

A 公司參考 ISACA BMIS 建立的企業資訊安全四個主要元素：人員、組織、流程、技術訂定母公司與子公司之「資訊安全績效指標」，結合美國國家標準技術研究所發布之 NIST SP800-55 資訊安全績效量測指南、ISO 27004 資訊安全管理量測標準及國內相關研究資料，分析出資安績效指標應涵蓋「專業能力」、「風控、法遵、稽核」、「例行維運」、「策略專案」、「創新」等績效指標面向，如圖 4-6，其中績效指標「整合分析、及早回應」係參酌 MITRE ATT&CK 架構(MITRE 是美國政府資助之非營利組織，協助進行資安相關研究；ATT&CK 係對手戰術、技術、公共知識庫之簡稱)，依據人員在資安攻擊事件各階段之防禦作為，設計加分及扣分項目，期望激勵資安人員積極查處、防制資安異常事件；透過訂定適用於集團整體一致性「資訊安全績效指標」，可藉此驅動子公司校準母公司資安策略方向，促進資安管理體系均衡發展，達到提高整體「資訊安全防護成效」之目的。

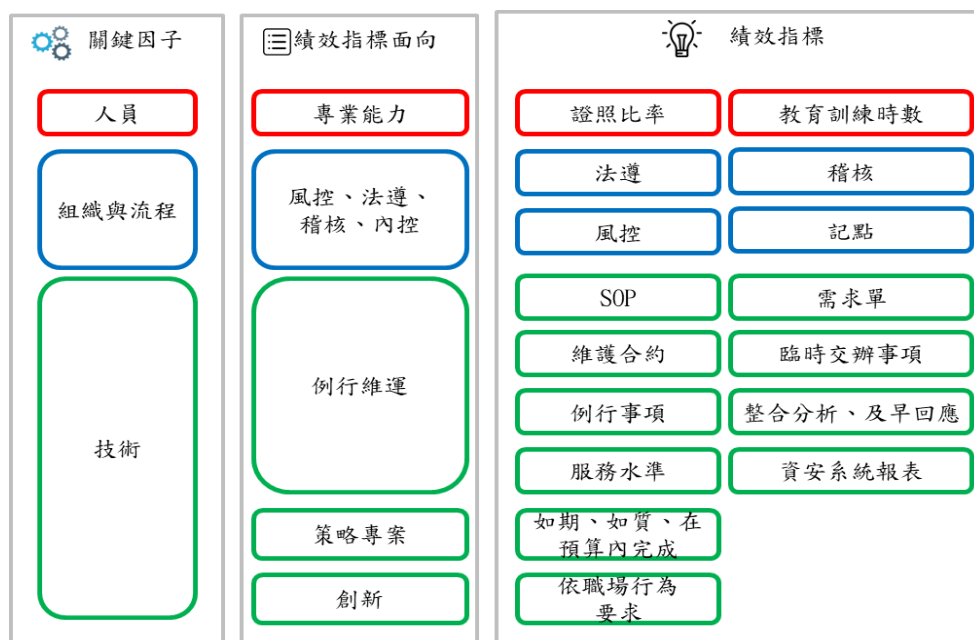


圖 4-6 A 公司資訊安全專責人員績效指標

資料來源：本研究整理

第五章 結論與建議



第一節、研究結論

本研究經探討資訊安全治理、資訊安全框架、資訊安全防禦技術、資訊安全績效評量相關文獻後，提出資訊安全治理與資訊安全框架整合應用架構，含資安治理、資安防護、資安韌性三個主要構面，及治理架構、制度規範、資安素養、管理機制、風險識別、防護技術、情蒐分析能力、偵測應變能力、資安聯防機制、營運持續能力等十個子構面，期待以化繁為簡之方式，協助金融業資訊安全權責主管，用以提升資訊安全治理成熟度，並設計十項資訊安全績效指標，含資安治理成熟度評估結果、內外部稽核缺失數量、資安人才證照比例、接受並通過資安培訓的人員比例、社交工程演練點擊率、專案如期如質如預算達成率、關鍵風險指標達成率、發生作業風險事件等級之資安事件數量、資安事件通報查處回應成效、作業符合服務水準及復原時間目標等，可用以向董事會成員呈報資訊安全治理成效，最後提出資安治理與管理框架建構七項步驟，並以企業實際案例實證其可行性。

案例 A 公司於 2017 年起已連續入選 DJSI 道瓊永續指數最高等級「世界指數 (DJSI World)」成分股(資安得分皆維持 PR 值 98 以上)，其子公司於 2017 年亦連續取得保險事業發展中心之「資訊安全推展卓越獎」，2020 年取得台灣企業永續學院之「資訊安全獎」，2021 年取得台灣企業永續學院之「資訊安全領袖獎」、香港「網路安全優質企業獎」、2021 年取得工商時報數位資訊安全獎，亦顯示 A 公司及其子公司使用本研究所提出之資訊安全治理與管理框架之具體成效。

故本研究在第一章第二節「研究動機與目的」所提出之八個應思考議題，即可透過第三章「資訊安全治理與資訊安全框架之整合應用」與第四章「建構符合資安治理與管理框架實作研究」得到結論。讓我們再回顧一次這些議題與本研究提出的答案關係。

一、如何與董事會成員報告資安治理成效？

使用資安治理與管理框架建構步驟之第一項「審視內外議題權重，擬定資安策略」、第二項「依據組織資源特性，設計治理架構與資安權責」、第七項「形塑全面資安文化，提升資安治理成熟度」。



二、如何因應快速變化的時空環境，考量資訊系統環境與資訊安全威脅，評估公司所需面對的資訊安全風險？

使用資安治理與管理框架建構步驟之第五項「鞏固縱深防禦，慎選資安合作夥伴」、第六項「建立資安韌性與聯防體系」。

三、隨著集團的併購與擴張，如何在子公司不同業態文化下，還能營造能校準集團策略的資訊安全文化？

使用資安治理與管理框架建構步驟之第三項「校準金檢查核重點，持續完備資安規範」、第七項「形塑全面資安文化，提升資安治理成熟度」。

四、如何在資源有限的情況下，去擬定能平衡風險與成本的聯防策略？

使用資安治理與管理框架建構步驟之第五項「鞏固縱深防禦，慎選資安合作夥伴」、第六項「建立資安韌性與聯防體系」。

五、資訊安全專責單位與資訊單位要如何分工合作才能有落實資訊安全工作？

使用資安治理與管理框架建構步驟之第二項「依據組織資源特性，設計治理架構與資安權責」。

六、在資訊安全人才短缺的情況下，如何選用育留資訊安全人才？

使用資安治理與管理框架建構步驟之第四項「順應國際主流趨勢，培育資安人才發展」。

七、如何設計與部署資訊安全防護機制，有效防禦資訊安全威脅？

使用資安治理與管理框架建構步驟之第五項「鞏固縱深防禦，慎選資安合作夥伴」、第六項「建立資安韌性與聯防體系」。

八、如何評量資訊安全防禦成效，評估資訊安全治理成熟度？

使用資安治理與管理框架第一項「審視內外議題權重，擬定資安策略」、第二項「依據組織資源特性，設計治理架構與資安權責」、第七項「形塑全面資安文化，提升資安治理成熟度」。

在本論文完成的這個時間(2021 年 12 月)，金管會剛於 2021 年 11 月 25 日預告修正「公開發行公司建立內部控制制度處理準則」將上市(櫃)公司依規模大小等條件分為三級(第一級 111 家、第二級 1,321 家、第三級 266 家)，要求第一級應於 2022 年設置資安長及資安專責單位，第二級應於 2023 年設置資安專責主管及至少 1 名資安專責人員，第三級鼓勵配置至少 1 名資安專責人員，並於 2021 年 12 月 23 日完成預告，將於近期發布施行。

金管會於 2021 年 11 月 30 日公告「公開發行公司年報應行記載事項準則」要求於年報中敘明資通安全風險管理架構、資通安全政策、具體管理方案及投入資通安全管理之資源，及列明因重大資通安全事件所遭受之損失、可能影響及因應措施等資訊。

金管會於 2021 年 12 月 21 日公布之 2022 年金融檢查重點中，特別強調金融消費者保護/金融友善服務/公平待客、資安管理及個資保護、公司治理與風險管理等 3 大類，為金管會首要檢查關注重點，而在資安管理及個資保護細部檢查重點說明中亦提及董事會資安治理、資安專責單位與主管職能發揮、營運持續管理等議題。

因此，已可明確預見會有更多企業資安主管或人員會遇到本研究所提到之議題並思求解方，筆者真心期待本研究所提出的建議可供金融同業及產業各界參酌使用。

第二節、研究限制

本研究僅探討國內金融業的資訊安全治理與管理框架實作應用，資料來源為公開的揭露訊息、學術期刊、知識網站資料及學生本身的實務經驗，資料內容因受限於保密機制、時間、及能力，對於個案資料收集、分析有所侷限，僅以架構與實例加以論述，而未引用相關調查或統計分析之數據，且受限於個案之金融業背景，本研究所提出「資安治理與管理框架」，並未確認是否對其他產業具有一體之適用性，以上所述為本研究之限制。





第三節、後續研究建議

首先，如第二章第一節所述，資訊安全治理範圍包含「資訊安全治理」本身，以及「資訊技術治理」，在歷史的演進上，資訊安全治理本就是完整資訊治理中不可或缺的一個關鍵領域，故實務上許多企業，在考量資訊單位與資訊安全緊密關係、管理成本、管理效益之下，仍未有獨立資訊安全專責單位之設計；故成立資訊安全專責單位，到底對資訊安全成效是好還是壞？此議題可待金融業資訊安全專責單位成立且運作一段時日後，待後人研究。

其次，本研究提出之資訊安全治理主要構面及子構面、十項資訊安全績效指標，係以筆者多年資安實務經驗分析歸納而得，應可適用多數金融業資安治理需求，但亦將隨著資訊安全治理、資訊安全框架、資訊安全國際標準之不斷演進而須修正內涵與整合方式，可待後續研究。

最後，金融業面臨另一重要議題就是金融科技（FinTech）的發展與應用，而在金融持續利用科技創新的同時，也會在新技術(例如人工智慧、大數據、雲端科技、機器人、物聯網等技術)與人員、流程結合並應用的過程中，隨之不斷產生新的資訊安全風險議題；隨著企業與客戶建立更緊密互動的關係、企業與供應商邊界的模糊化、企業培養其生態系的過程中，致使企業與外部世界的接觸點更趨多元，攻擊者可以入侵企業的可能管道也更趨多元，內外部風險因子亦變得更為複雜，因此未來後續研究可以針對金融生態系及其他產業防禦策略與管理架構持續探討，或針對資訊安全重要關鍵因素對資安治理之影響持續探討，如安全的軟體開發生命週期(SSDLC)、物聯網安全、供應鏈安全、實體安全等，並持續評估更多績效衡量指標對資安治理的影響，進而應用於其他產業，完善資訊安全績效評量構面，提升我國整體資訊安全治理成熟度。

參考文獻



一、中文部份

1. iThome, 2019, **【臺灣資安大會直擊】金管會大談四大金融資安監理，顧立雄更要金融業將資安視為業務創新的基石**，
<https://www.ithome.com.tw/news/129508>，搜尋日期 2020 年 1 月 26 日。
2. iThome, 2020, **F-ISAC 屆滿三年，金管會揭露推動進度與成果，將推動金融機構資安治理成熟度評估**，<https://www.ithome.com.tw/news/140906>，搜尋日期 2020 年 1 月 26 日。
3. iThome, 2021, **台灣資安市場地圖**，<https://www.ithome.com.tw/aboutus/>，搜尋日期 2021 年 2 月 24 日。
4. MBA 智庫百科, 2021, **績效管理**，<https://wiki.mbalib.com/zh-tw/绩效管理>，搜尋日期 2021 年 2 月 24 日。
5. 中國民國資訊軟體協會, 2019, **台灣資安產品及服務通過能量登錄服務機構地圖**，<https://www.acw.org.tw/News/Detail.aspx?id=107>，搜尋日期 2021 年 2 月 24 日。
6. 王希文, 2021, **談金融生態圈之發展及規範：以電子支付、純網路銀行及開放銀行為中心**，國立中正大學財經法律系研究所碩士論文。
7. 王東紅、孫強、陳偉, 2004, **信息安全管理：全球最佳實務與實施指南**，
https://books.google.com.tw/books?id=-5QxgpIab4kC&pg=PR5&dq=%E4%BF%A1%E6%81%AF%E5%AE%89%E5%85%A8%E6%B2%BB%E7%90%86&hl=zh-TW&sa=X&ved=2ahUKEwi2h47r8ubzAhU-xIsBHTJ_D3IQ6AF6BAgJEAI#v=onepage&q=%E4%BF%A1%E6%81%AF%E5%AE%89%E5%85%A8%E6%B2%BB%E7%90%86&f=false，搜尋日期 2020 年 1 月 26 日。
8. 台灣證券交易所, 2019, **公司治理宣導**，
<https://www.twse.com.tw/staticFiles/news/event/ff80808167ee6fd01695b06fe7b07be.pdf>，搜尋日期 2020 年 12 月 29 日。

- 
9. 行政院國家資通安全會報技術服務中心資安人才培訓服務網，2020，**資安專職人力職能**，<https://ctts.nccst.nat.gov.tw/about/Training>，搜尋日期 2020 年 10 月 23 日。
10. 行政院資通安全處，2017，**資通安全管理法與發展藍圖**，<https://s.itho.me/egov/2017/A-1320.pdf>，搜尋日期 2020 年 1 月 26 日。
11. 行政院資通安全處，2018，**資通安全情資分享實務**，http://download.nccst.nat.gov.tw/attachfilehandout/05._資通安全情資分享實務_v.7.pdf
12. 李于宏，2021，防護刻不容緩資安求才若渴，**財金資訊季刊**，第 100 期：38-45。
13. 李吉仁，2011，**對的組織勝過好的策略**，https://www.hbrtaiwan.com/article_content_AR0001821.html，搜尋日期 2021 年 12 月 2 日。
14. 李吉仁，2019，**驅動轉型成為轉機**，https://www.hbrtaiwan.com/article_content_AR0008782.html，搜尋日期 2021 年 12 月 2 日。
15. 李芊曄、劉洪森、葛迎、曾希雯、李雙喜、李燁茗、趙彤彤、袁俊、劉玲麟、洪瑋、洪振宇，2020，**網路安全框架 1.1**，搜尋日期 2020 年 1 月 26 日。
16. 李坤達，2011，**證券業資訊人員資訊安全認知對資安治理影響之研究**，淡江大學資訊管理學系碩士在職專班碩士論文。
17. 季祥，2014，**APT 攻擊對企業資安政策之影響**，中國文化大學商學院資訊管理學系碩士論文。
18. 金融監督管理委員會，2013，**強化公司治理藍圖**，[https://www.fsc.gov.tw/fckdowndoc?file=/2013%E5%BC%B7%E5%8C%96%E6%88%91%E5%9C%8B%E5%85%AC%E5%8F%B8%E6%B2%BB%E7%90%86%E8%97%8D%E5%9C%96\(1\).pdf&flag=doc](https://www.fsc.gov.tw/fckdowndoc?file=/2013%E5%BC%B7%E5%8C%96%E6%88%91%E5%9C%8B%E5%85%AC%E5%8F%B8%E6%B2%BB%E7%90%86%E8%97%8D%E5%9C%96(1).pdf&flag=doc)，搜尋日期 2020 年 12 月 29 日。
19. 金融監督管理委員會，2016，**金融科技發展策略白皮書**，<https://www.fsc.gov.tw/ch/home.jsp?id=517&parentpath=0,7,478>，搜尋日期 2020 年 1 月 23 日。



20. 金融監督管理委員會，2020，**金融科技發展路徑圖**，
<https://www.fsc.gov.tw/ch/home.jsp?id=975&parentpath=0>，搜尋日期 2020 年 12 月 29 日。
21. 金融監督管理委員會，2020，**金融資安行動方案**，
<https://www.fsc.gov.tw/ch/home.jsp?id=975&parentpath=0>，搜尋日期 2021 年 2 月 24 日。
22. 金融監督管理委員會，2021，**金融科技發展路徑圖金管會公布 111 年度金融查重點**，
https://www.feb.gov.tw/ch/home.jsp?id=53&parentpath=0,2&mcustomize=multimessage_view.jsp&dataserno=202112210001&aplistdn=ou=news,ou=multisite,ou=chinese,ou=ap_root,o=fsc,c=tw&table=News，搜尋日期 2021 年 12 月 21 日。
23. 洪孟芬，1985，**資訊安全保護系統的存取控制技術**，國立中興大學應用數學研究所碩士論文。
24. 洪智能，2012，**我國大專校院資安治理成熟度及其相關因素之分析**，淡江大學管理科學學系博士班論文。
25. 國際電腦稽核協會，2019，**協會簡介**，<https://www.isaca.org.tw/about/1>，搜尋日期 2020 年 1 月 26 日。
26. 陳慶儒，2016，**影響資訊安全管理策略效益因素研究-以 C 金控公司為例**，國立台北商業大學商學研究所碩士論文。
27. 彭仁岡，2004，**國家資通訊安全管理之策略規劃探討**，國立台灣科技大學資訊管理系碩士論文。
28. 湯明哲、李吉仁與黃崇興，2014，**管理相對論(初版)**，台北：城邦商業週刊。
29. 經濟部工業局，2019，**經濟部工業局 108 年度資安專業人才職能分析報告**，
<https://www.acwacademy.org.tw/functional-benchmark/>，搜尋日期 2020 年 10 月 23 日。
30. 經濟部標準檢驗局，2013，**CNS 27014**，
https://www.cnsonline.com.tw/?node=result&typeof=common&locale=zh_TW，搜尋日期 2020 年 1 月 20 日。

- 
31. 維基百科，2020，**國際標準化組織**，<https://zh.wikipedia.org/wiki/國際標準化組織>，搜尋日期 2020 年 1 月 20 日。
 32. 樊國楨、黃健誠，2009，資安治理推動方案與落實電子化資安管理初探，**資訊安全通訊**，15 卷 4 期：1-23。
 33. 潘世鳴、朱惠中，2011，**量測資訊安全管理系統有效性方法之研究**，第十七屆資訊管理暨實務研討會，台灣台南。
 34. 蔡福隆，2018，推動我國金融資安聯防體系，**財金資訊季刊**，第 94 期：2-6。
 35. 蕭瑞祥，2013，我國推動資安治理之建議，**主計月刊**，686 期：34-40。
 36. 總統府，2018，**國家資通安全戰略報告**，
<https://www.president.gov.tw/File/Doc/588f1a08-5ea7-41df-b0d0-482a00b45322>，搜尋日期 2020 年 1 月 24 日。
 37. 趨勢科技，2012，**認識 APT-進階持續性滲透攻擊**，
<https://blog.trendmicro.com.tw/?p=986>，搜尋日期 2020 年 1 月 26 日。
 38. 蘇凡真，2015，**銀行業的資訊安全成熟度評估模式探討**，大同大學事業經營研究所碩士論文。

二、英文部份

1. Corporate Governance Task Force. 2004. **Information Security Governance A Call to Action**.
<http://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.535.6634&rep=rep1&type=pdf>. Accessed Feb. 26, 2021.
2. Gartner. 2001. **The Gartner Security Process Maturity Model**.
<https://www.gartner.com/en/documents/326006/the-gartner-security-process-maturity-model>. Accessed Aug. 26, 2021.
3. International Organization for Standardization. 2017. **ISO 22316:2017**.
<https://www.iso.org/obp/ui#iso:std:iso:22316:ed-1:v1:en>. Accessed Sep. 20, 2021.
4. International Organization for Standardization. 2019. **ISO 22301:2019**.
<https://www.iso.org/obp/ui#iso:std:iso:22301:ed-2:v1:en>. Accessed Sep. 20, 2021.
5. International Organization for Standardization. 2020. **About us**.
<https://www.iso.org/about-us.html>. Accessed Jan. 20, 2020.

- 
6. ISACA. 2010. *The Business Model for Information Security*.
https://books.google.com.tw/books?id=Cv_Jq_23iEsC&printsec=frontcover&hl=zh-TW&source=gbg_summary_r&cad=0#v=onepage&q&f=false. Accessed Jan. 26, 2020.
 7. ISACA. 2017. *Enterprise Security Architecture—A Top-down Approach*.
<https://www.isaca.org/resources/isaca-journal/issues/2017/volume-4/enterprise-security-architecture-a-top-down-approach>. Accessed Aug. 26, 2021.
 8. ISMS online. 2016. *ISO 27004*. <https://www.isms.online/iso-27004/>. Accessed Feb. 26, 2021.
 9. Johnson, Everett C. 2006. Security Awareness: Switch to a Better Programme. *Network Security*, 2006(2):15–18.
 10. National Institute of Standards and Technology. 2004. *Guide to Selecting Information Technology Security Products*.
<https://csrc.nist.gov/publications/detail/itl-bulletin/2004/04/selecting-information-technology-security-products/final>. Accessed Feb. 27, 2021.
 11. National Institute of Standards and Technology. 2008. *Performance Measurement Guide for Information Security*. <https://csrc.nist.gov/publications/detail/sp/800-55/rev-1/final>. Accessed Feb. 26, 2021
 12. National Institute of Standards and Technology. 2020. *About NIST*.
<https://www.nist.gov/about-nist>. Accessed Jan. 26, 2020.
 13. Posthumus, Shaun, and Rossouw von Solms. 2004. A Framework for the Governance of Information Security. *Computers & Security*, 23(8):638-646.
 14. Relyea, Harold C. 2008. Federal Government Information Policy and Public Policy Analysis: A Brief Overview. *Library & Information Science Research*, 30(1):2–21.
 15. S.H. Von Solms and R.Von Solms. 2009. *Information Security Governance by S.H. von Solms, Rossouw von Solms*. Springer Science+Business Media, LLC.
 16. SABSA. 2021. *SABSA Executive Summary*. <https://sabsa.org/sabsa-executive-summary/#why-is-sabsa-so-successful>. Accessed Aug. 26, 2021.
 17. Wikipedia. 2013. *Sherwood Applied Business Security Architecture*.
https://en.wikipedia.org/wiki/Sherwood_Applied_Business_Security_Architecture. Accessed Aug. 26, 2021.
 18. Williams, Paul. 2001. Information Security Governance. *Information Security Technical Report*, 6(3):60–70.